

KADDOURI Kélian

ENSAE 3^{ème} année
Stage de fin d'études

Année scolaire 2025-2026

Quantification du SCR lié à la non-conformité au règlement DORA

Une cascade dirigée entre les cinq piliers, dont l'état de conformité
pilote le capital

Nexialog Consulting
Paris, France

Maître de stage : [Prénom NOM]
[date de début] au [date de fin]

Table des matières

1	Introduction	4
2	Le problème et son analyse	5
2.1	Ce que le stage devait produire	5
2.2	DORA et Solvabilité II, deux textes qui ne se rejoignent pas	6
2.3	La question retenue	7
2.4	Positionnement dans la littérature	7
3	Les données et les outils	7
3.1	Sept sources et leur statut de preuve	7
3.2	Les limites de la donnée, mesurées	8
3.3	Retraitements et convention de population	9
3.4	La calibration de la sévérité et son gel	10
3.5	Les outils de calcul	11
3.6	Le contrôle des chiffres publiés	11
4	La méthode	12
4.1	La cascade dirigée	12
4.2	Trois propriétés démontrées	13
4.3	L'état de conformité comme variable de pilotage	14
4.4	La frontière d'identifiabilité	15
4.5	L'identification partielle	16
4.6	Les quatre canaux de conformité	17
5	Résultats et critique	18
5.1	Le chiffre central et son encadrement	18
5.2	Attribution par canal et par pilier	19
5.3	Analyse de sensibilité	22
5.4	Trajectoire et durée de non-conformité	23
5.5	Validation hors échantillon	24
5.6	La règle de sélection du seuil	25
5.7	Du secteur à l'entité	26
5.8	Application à quatre entités réelles	27
5.9	Inventaire des limites	27
5.10	Quelle grandeur reporter	28
5.11	Mise en regard des cadres existants	30
5.12	Lecture économique	31
6	Enseignements du stage	31
6.1	Les enseignements de l'ENSAE mobilisés	31
6.2	La part de l'encadrement et des tiers	32
6.3	Ce que j'en retiens	33
6.4	Ce que je ferais autrement	34
7	Conclusion	34
A	Les paramètres du modèle	37

B Chronologie du stage	37
Note de synthèse (français)	38
Note de synthèse (English)	40

1 Introduction

Ce stage de fin d'études s'est déroulé chez Nexialog Consulting, cabinet de conseil spécialisé dans la modélisation des risques pour les établissements financiers, au sein de l'activité de recherche appliquée. Il a donné lieu à un mémoire d'actuariat, dont ce rapport présente la démarche, les résultats et le recul que plusieurs mois de travail permettent d'en avoir. La chronologie des jalons figure en annexe B.

Le sujet vient du règlement européen DORA (DOR, 2022), entré en application en janvier 2025, qui impose aux entités financières la maîtrise de cinq domaines de résilience opérationnelle numérique : la gouvernance du risque lié aux technologies (P1), la gestion et la notification des incidents (P2), les tests de résilience (P3), la gestion du risque lié aux prestataires tiers (P4) et le partage d'informations sur les cybermenaces (P5). Le texte est prescriptif sur les dispositifs à mettre en place et muet sur leur traduction en capital. Un assureur qui demande à son consultant ce que lui coûte un retard de conformité n'obtient donc aujourd'hui aucune réponse chiffrée issue d'un cadre reconnu.

Le problème posé. La question confiée n'était pas de mesurer l'état de conformité d'une entité, exercice d'audit pour lequel les grilles existent, mais de répondre à une question de modélisation : *combien coûte, en capital de solvabilité, de ne pas se conformer, et jusqu'où ce chiffre peut-il être affirmé.* La seconde moitié de la phrase s'est révélée être le vrai sujet.

Deux constats en fixent la difficulté. Le premier est que la Formule Standard de Solvabilité II charge le risque opérationnel par un forfait,

$$SCR_{op} = \min(0,3 BSCR ; 0,03 \max(\text{primes}, \text{provisions})),$$

indifférent au fait qu'une entité soit exemplaire ou défaillante sur DORA : deux assureurs de même taille et de maturité opposée y portent la même charge. Le second est que les cinq piliers ne sont pas des cases indépendantes à cocher. Ce sont des domaines de contrôle, et la défaillance de l'un dégrade la capacité de tenir les autres : une gouvernance défaillante retarde la détection des incidents, un prestataire mal maîtrisé ouvre une porte que les tests n'ont pas explorée. La non-conformité ne reste pas dans son pilier, elle se propage, et elle se propage dans un sens.

C'est cette asymétrie qui interdit les outils habituels. Une copule capturerait la co-occurrence des pertes, mais symétriquement : elle ne distingue pas une défaillance qui *entraîne* les autres d'une défaillance qui les *subit*. Or c'est la direction qui devrait commander l'ordre de remédiation d'un assureur, puisque corriger une cause vaut mieux que corriger un symptôme.

Les moyens employés. Le travail est entièrement quantitatif et repose sur quatre éléments. Une chaîne de calcul en Python, organisée en une centaine de scripts numérotés qui produisent chacun une sortie texte versionnée et, pour la plupart, une figure. Sept sources de données, publiques ou sous licence, dont aucune n'a été construite pour répondre à la question posée,

ce qui est le cœur de la difficulté. Un document L^AT_EX de près de cent quatre-vingts pages, le mémoire d'actuariat. Et un dispositif de vérification, développé pendant le stage, qui cherche chaque nombre publié dans les sorties des scripts que sa section cite et refuse ceux qu'il ne retrouve pas.

Deux retournements, annoncés d'emblée. Ce rapport serait malhonnête s'il présentait une trajectoire linéaire. La propriété qui donnait son titre au projet, la non-transitivité de la criticité entre piliers, a été **réfutée par mes propres calculs** dans ses trois acceptions, et remplacée par une propriété plus faible mais vraie, la dépendance à l'ordre. Et le chiffre central du travail a été requalifié de mesure en **borne supérieure d'ordre de grandeur** après lecture de quatre rapports de solvabilité réels. Ces deux corrections viennent du travail lui-même et non d'une demande extérieure ; elles sont, à mon sens, ce que le stage m'a le mieux appris.

Le rapport suit l'ordre du raisonnement : le problème et son analyse (§2), les données et les outils (§3), la méthode construite (§4), les résultats et leur critique (§5), puis ce que le stage a mobilisé de la formation (§6).

Sources : scripts 27 (forfait de Formule Standard), 28 et 29 (périmètre et comptages).

2 Le problème et son analyse

2.1 Ce que le stage devait produire

La demande initiale, telle qu'un client la formule, est un nombre : le coût en capital d'un défaut de conformité. L'analyse a consisté d'abord à établir qu'un tel nombre ne peut pas être produit honnêtement en l'état, puis à définir ce qui peut l'être. Trois obstacles s'en dégagent, de natures différentes.

Le premier est un manque de cadre. Il n'existe aucun module DORA en Formule Standard, donc la grandeur calculée n'est pas un SCR réglementaire. Le vocabulaire du mémoire s'en tient à « besoin de capital au titre de l'évaluation interne », et le rapport de cette grandeur au SCR publié d'une entité y est présenté comme une mise à l'échelle, non comme une part. Ce n'est pas une précaution de style : présenter un chiffre comme une composante réglementaire d'un SCR serait faux.

Le deuxième est un manque de donnée, et c'est le plus intéressant. La direction de la propagation entre domaines de contrôle n'est pas observable dans les bases disponibles : on y voit des incidents qui touchent plusieurs domaines à la fois, donc de la co-occurrence, mais jamais l'ordre dans lequel les domaines ont cédé. Cet obstacle est devenu la contribution principale du travail, par le retournement de méthode décrit au §4.5.

Le troisième est un manque de mesure sur l'objet même de la question. L'état de conformité d'une entité réelle n'est pas public, et il n'était pas question de le supposer pour une entité nommée. Le travail porte donc sur des états de conformité *hypothétiques* et sur l'écart entre eux,

ce qui déplace la question : le niveau absolu du capital devient illustratif, et ce qui est défendu est le rapport entre deux états et la hiérarchie des piliers.

2.2 DORA et Solvabilité II, deux textes qui ne se rejoignent pas

L'articulation des deux textes crée précisément le vide que le travail comble.

DORA est un règlement de *moyens*. Il impose un cadre de gouvernance du risque informatique porté par l'organe de direction, un processus de classification et de notification des incidents majeurs assorti de délais, un programme de tests de résilience incluant des tests d'intrusion fondés sur la menace pour les entités les plus significatives, un registre d'information sur les accords conclus avec les prestataires tiers de services informatiques ainsi qu'un régime de surveillance des prestataires jugés critiques, et un cadre volontaire de partage d'informations sur les cybermenaces. Aucune de ces obligations ne s'accompagne d'une exigence quantitative de capital, ce qui est cohérent avec la nature du texte : DORA relève de la résilience opérationnelle, non de la solvabilité.

Solvabilité II, symétriquement, quantifie sans regarder le dispositif. Le risque cyber n'y dispose d'aucun module dédié : il est absorbé, selon la nature de la perte, par le module de risque opérationnel, par la responsabilité civile pour la part assurée, ou par les provisions. Et le module de risque opérationnel est le forfait rappelé en introduction, qui ne dépend que de la taille de l'activité.

Il en résulte une asymétrie qui est le point de départ légitime du travail : le régulateur demande des dispositifs sans en tarifier l'absence, et la mesure de capital est aveugle à la qualité de ces dispositifs. Le pont entre les deux n'est donc pas la Formule Standard mais le **pilier 2**, l'évaluation interne des risques et de la solvabilité, où une entité est libre de représenter un risque comme elle l'estime juste. C'est le cadre dans lequel la grandeur calculée ici a un sens.

Une confusion d'échelles, et la convention qui la règle. Deux grandeurs de natures différentes circulaient sous le même nom : le quantile de la sévérité d'un *sinistre unique*, qui vaut 662,78 M€, et le quantile de la *charge annuelle agrégée*, seul à porter un sens réglementaire au niveau de 99,5 %. Présentées côte à côte lors d'une réunion d'avancement, l'une valant quelques centaines de millions et l'autre plusieurs milliards, elles ont fait conclure à une incohérence. Deux notations distinctes ont été introduites, et le pont entre les deux échelles est désormais calculé plutôt qu'estimé de tête. Le résultat qui ferme la question est que leur rapport *s'inverse* avec l'échelle, valant 12,3 au niveau sectoriel et 0,30 au niveau d'une entité : aucun rapport fixe ne les relie, donc les comparer ne conclut jamais.

Sources : scripts 07 (calibration de sévérité), 28 (mise en regard réglementaire), 60 (intensité annuelle) et 67, section 1bis (pont entre les deux échelles).

2.3 La question retenue

De cette analyse découle la question effectivement traitée, en trois volets qui correspondent aux trois apports du mémoire.

1. **Construire un mécanisme** de dépendance dirigée entre les cinq piliers, dont les propriétés soient démontrées au lieu d'être supposées, et dont la stabilité soit garantie par construction plutôt que vérifiée après coup.
2. **Établir ce que la donnée permet d'en estimer**, et le démontrer plutôt que le déplorer : quelle partie du mécanisme est identifiable, laquelle ne l'est pas, et pour quelle raison mathématique.
3. **Transformer cette limite en méthode** : puisque la direction n'est pas identifiable, ne pas la poser, mais borner le capital sur l'ensemble des matrices compatibles avec la donnée, et chiffrer en euros ce que l'information manquante coûte.

Ce découpage a une conséquence de rédaction tenue jusqu'au bout : aucun niveau de capital agrégé n'apparaît dans le mémoire avant la partie consacrée aux résultats. Les parties qui établissent les données, le modèle et l'identifiabilité n'énoncent que des écarts relatifs. Un lecteur ne peut donc pas prélever un chiffre avant d'avoir lu ce qui le borne.

2.4 Positionnement dans la littérature

Le travail se situe à l'intersection de trois courants. La modélisation actuarielle du risque cyber, où la sévérité est traitée par la théorie des valeurs extrêmes (Eling and Wirfs, 2019 ; Herath and Herath, 2011) et où les états de conformité ont déjà servi de variable de pilotage (Hillairet and Lopez, 2021). Les processus auto-excités, employés pour représenter la contagion temporelle des incidents (Bessy-Roland et al., 2021 ; Boumezoued et al., 2023). Et l'économétrie de l'identification partielle (Manski, 1990 ; Tamer, 2010), qui fournit l'outil décisif : produire un ensemble de valeurs compatibles avec la donnée plutôt qu'un point qu'elle ne détermine pas.

L'apport propre est le croisement du premier et du troisième. À ma connaissance, la dépendance entre domaines de contrôle réglementaires n'avait pas été traitée comme un problème d'identification, et c'est ce déplacement qui permet de publier un résultat là où la donnée ne permet pas de publier une mesure.

3 Les données et les outils

3.1 Sept sources et leur statut de preuve

Le travail mobilise sept sources, chacune pour ce qu'elle sait et pour elle seule. Ce cloisonnement est délibéré : la principale erreur possible ici est de faire porter à une base un énoncé qu'elle ne soutient pas.

Source	Ce qu'elle fournit	Volume utilisé	Statut de preuve
Base internationale de pertes opérationnelles	sévérité, queue de distribution	91 excès au seuil de 20,03 M€	sous licence, non redistribuable
Chronologie de violations de données	fréquence annuelle, dimension temporelle	vingt-deux années, 2004 à 2025	reproductible par script
Schéma d'incidents structuré	décomposition en sous-piliers	10 591 incidents, dont 1 renseigné sur les deux champs requis	reproductible par script
Corpus de rapports post-incident officiels	structure dirigée de la propagation	22 cellules directionnelles sur 100	codage manuel, grille publiée
Panorama annuel d'incidents	parts par vecteur d'attaque	1 041 incidents, dont 840 à vecteur identifié	citation externe non recalculable
Rapports de solvabilité publics	bilans et SCR d'entités réelles	quatre entités, exercice 2024	public, entités anonymisées
Étude de marché de la cyberassurance	cadrage du marché français	20 996 polices, 1 251 sinistres	citation externe non recalculable

TABLE 1. Les sept sources et leur statut de preuve.

Lecture. La dernière colonne est celle qui compte, et elle a fait l'objet d'un arbitrage. Deux sources ont été consultées puis non conservées : leurs chiffres ne sont reproductibles par aucun script, ce qui les place hors du dispositif de vérification. Deux traitements étaient possibles, retirer la source ou assumer une citation datée. Le second a été retenu, à une condition : que le statut soit écrit dans le document, imprimé par un script sous l'étiquette de citation externe, et que ces sources ne portent que de la *structure* et jamais un *niveau*. Le panorama d'incidents fournit ainsi la décomposition de la fréquence par vecteur d'attaque, jamais la fréquence elle-même.

Sources de la table : scripts 07 (excès au seuil), 28 (schéma structuré), 53 et 54 (corpus et grille de codage), 62 (comptages), 63 (citations externes) et 65 (bilans réels).

3.2 Les limites de la donnée, mesurées

Trois limites ont été mesurées plutôt qu'invoquées.

La troncature de collecte. Les bases de pertes ne recensent que les sinistres au-delà d'un seuil de déclaration. Le capital calculé est donc un capital de *queue*, et l'attritionnel en est absent par absence d'observation. Deux éléments atténuent la portée de cette limite sans l'effacer : au niveau de 99,5 % la charge est portée par un sinistre unique, donc l'attritionnel y pèse peu par construction, et à l'échelle d'une entité 98,8 % des années sont sans aucun incident matériel.

Le biais de taille. Les grandes institutions déclarent davantage. Ce biais a été estimé, et l'élasticité de la sévérité à la taille vaut 0,087, d'intervalle [0,026 ; 0,148], qui contient presque zéro. La conséquence est inconfortable et elle est publiée comme telle : le modèle affirme qu'une entité de quelques milliards d'euros de bilan subit à peu près la même sévérité qu'une institution mondiale. C'est ce qui a conduit à requalifier le chiffre d'entité en borne supérieure.

Le résultat négatif qui compte. Le schéma d'incidents structuré porte *exactement* les deux champs qui permettraient d'observer une direction, et ne renseigne les deux ensemble que dans un incident sur 10591. Ce n'est donc pas un défaut de la donnée disponible, c'est un défaut de la donnée *collectable en l'état* : le champ existe, la profession ne le remplit pas. Ce constat vaut mieux qu'une lacune constatée, parce qu'il désigne une action possible, et le mémoire chiffre en euros ce qu'un registre mieux spécifié rapporterait.

Sources : scripts 28 (champs du schéma), 57 (biais de taille et de troncature), 58 (années sans aucun sinistre à l'échelle d'entité), 60 (élasticité de fréquence) et 65 (bilans réels).

3.3 Retraitements et convention de population

Le travail de donnée proprement dit occupe une part du stage que je n'avais pas anticipée, et il porte une décision qui commande tous les résultats de sévérité : la définition de la population de pertes.

Trois filtres sont appliqués, dans cet ordre, et chacun a été un choix. Le **secteur**, restreint à la finance, parce qu'une perte de nature technologique dans l'industrie ne se traduit pas par la même exposition réglementaire. La **nature de l'événement**, restreinte à la catégorie technologique, ce qui exclut les fraudes internes et les litiges commerciaux qui dominent en volume les bases de risque opérationnel. Et l'**unité**, tous les montants étant ramenés en millions d'euros, ce qui suppose une conversion dont l'effet a été vérifié comme négligeable devant la dispersion des montants.

Ce triple filtre est écrit dans une fonction unique, appelée par tous les scripts qui touchent à la sévérité, et c'est une leçon d'organisation. La table des indices de queue par catégorie de risque opérationnel qui figurait initialement au mémoire provenait d'une extraction dont le filtre n'avait pas été conservé, et aucune combinaison du code ne la reproduisait. Elle a été refaite avec un filtre écrit, et les cinq valeurs ont changé. Une donnée dont le filtre n'est pas dans le code n'est pas une donnée, c'est un souvenir.

Un second retraitement a failli invalider un test. La fenêtre temporelle du backtest est choisie *sur la donnée* : avant 2004 la base porte un à neuf incidents par an contre treize à trente-neuf ensuite, et l'année courante n'en porte que cinq. Ce ne sont pas des années calmes, c'est une collecte qui ne les couvre pas. Une fenêtre plus large aurait fabriqué un faux régime tranquille au début et un faux effondrement à la fin, donc une fausse tendance, et le test aurait mesuré la profondeur de la collecte au lieu du risque.

Sources : scripts 62 (population filtrée), 67, section 5 (indices de queue par catégorie) et 89 (fenêtre du backtest).

3.4 La calibration de la sévérité et son gel

La sévérité est modélisée par dépassement de seuil, sur la base de la théorie des valeurs extrêmes (Pickands III, 1975 ; Balkema and de Haan, 1974 ; Embrechts et al., 1997). Au seuil retenu de 20,03 M€ la base compte 91 excès, et l'ajustement de Pareto généralisé donne un indice de queue $\hat{\xi} = 0,5954$ et une échelle $\hat{\sigma} = 57,97$. Le quantile de sévérité à 99,5 % d'un sinistre vaut 662,78 M€, d'intervalle de confiance à 90 % [411,5 ; 1 037] M€. La table complète des paramètres, avec leur statut, figure en annexe A.

L'ajustement est validé sur trois critères indépendants, présentés en figure 1 : les paramètres publiés, imposés au test, passent Anderson-Darling à $p = 0,99$ et Kolmogorov-Smirnov à $p = 0,89$, et la loi de comptage retenue, une binomiale négative, reproduit la queue de la distribution du nombre d'incidents là où une loi de Poisson l'écrase.

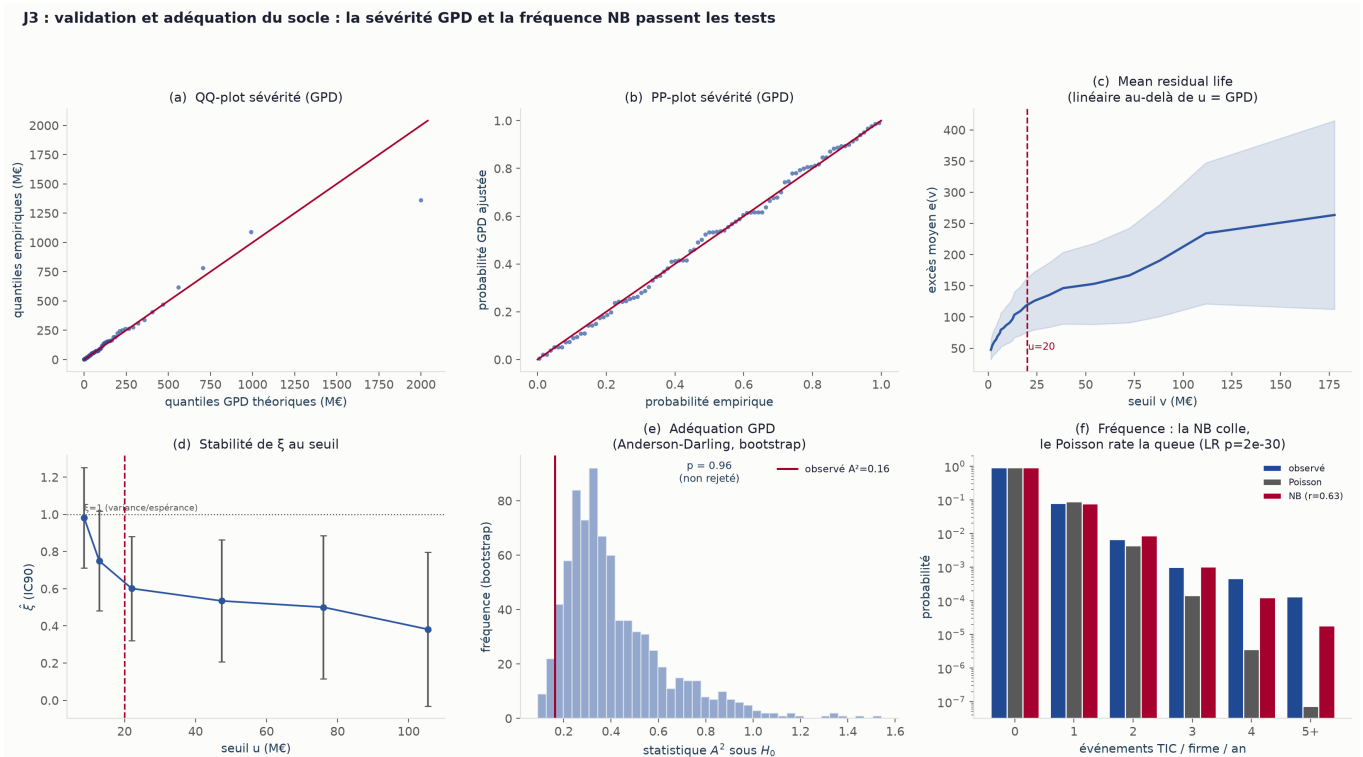


FIGURE 1. Adéquation du socle. (a) et (b) diagrammes quantile-quantile et probabilité-probabilité de l'ajustement de Pareto généralisé. (c) vie résiduelle moyenne, linéaire au-delà du seuil retenu, ce qui est la signature attendue d'une queue de Pareto. (d) sensibilité de l'indice de queue au seuil, avec son intervalle à 90 %. (e) test d'Anderson-Darling par bootstrap paramétrique : la p -valeur y diffère légèrement de celle du texte, qui impose les paramètres publiés là où le bootstrap les ré-estime sur chaque réplique ; les deux ne rejettent pas. (f) loi du nombre d'incidents par firme et par an, en échelle logarithmique : la binomiale négative suit la queue, la loi de Poisson la manque de plusieurs ordres de grandeur.

Le panneau (d) demande une précision, parce que le mémoire s'y était trompé. Il écrivait que l'indice de queue « se stabilise autour de 0,6 » quand on fait varier le seuil, ce que le ba-

layage démentit : la valeur décroît jusqu'à 0,38 au percentile 95. La lecture correcte coupe le balayage au seuil publié. Au-dessus, l'indice reste *entièrement dans l'intervalle déjà publié*, donc la sensibilité au seuil ne crée pas d'incertitude nouvelle, elle se lit dans celle qui est déclarée. En dessous, il remonte à 0,98 et sort de l'intervalle, ce qui est le biais de seuil classique et justifie de ne pas descendre plus bas. Le script imprimait en clair l'interdiction d'écrire la première version ; la sortie versionnée portait la consigne depuis des semaines et personne ne l'avait lue.

Le gel de la calibration. Cette calibration a été gelée le 7 août 2026, à mi-parcours du stage. À compter de cette date, aucun paramètre d'entrée n'a plus été modifié, et seules les corrections d'erreur sont restées autorisées. La distinction est nette et a été appliquée à la lettre : une erreur est une valeur qu'aucun calcul du projet ne reproduit, une recalibration est un changement d'entrée qui déplace des résultats corrects. Le motif du gel est qu'un document de cette taille, où plusieurs milliers de nombres publiés dépendent d'une chaîne stochastique, perd sa piste d'audit dès qu'on rejoue la chaîne : des centaines de nombres bougeraient sans qu'aucun déplacement soit attribuable à la correction.

Ce gel a une conséquence assumée. Un défaut de cohérence a été trouvé après lui : le taux de dépassement publié ne correspond pas exactement au nombre d'excès comptés au seuil publié. L'effet est calculé, il vaut +2,4 % sur le quantile, soit 15,8 M€, c'est-à-dire un quarantième de la largeur de l'intervalle de confiance de cette même grandeur. Le choix a été de **publier l'écart plutôt que de le corriger**, avec son sens : il sous-estime le capital, donc il se déclare du côté de la solvabilité. Ce choix se discute, et je le défends ainsi : une limite chiffrée, signée et recalculée à chaque exécution du code vaut mieux devant un jury qu'un nombre corrigé en silence.

Sources : scripts 07 (ajustement), 47 (tests d'adéquation, balayage de seuil, effet du taux de dépassement) et 63 (calibration figée).

3.5 Les outils de calcul

Les outils employés sont ceux de la formation : estimation par maximum de vraisemblance, tests d'adéquation d'Anderson-Darling et de Kolmogorov-Smirnov, bootstrap paramétrique, simulation de Monte-Carlo, variables latentes gaussiennes à facteur commun, chaînes de Markov à temps discret, estimation en différence de différences, et décomposition d'une grandeur par valeur de Shapley (Shapley, 1953) ou par indices de sensibilité (Iooss and Prieur, 2019). La mise en œuvre est en Python, avec les bibliothèques scientifiques usuelles. Le détail de ce que chaque enseignement fournit au travail est en table 13.

3.6 Le contrôle des chiffres publiés

L'outil dont je suis le plus satisfait n'est pas un modèle, c'est un dispositif de contrôle construit pendant le stage et qui n'était pas demandé. Chaque section du mémoire cite les scripts

dont elle tire ses nombres. Un programme relit le document, extrait tous les nombres publiés, et cherche chacun d’eux dans les sorties versionnées des scripts que sa section cite, à une tolérance d’arrondi égale à la demi-unité du dernier chiffre écrit. Il rend trois lignes et non une : les nombres vérifiés, ceux qui sont exemptés avec leur motif écrit, et ceux qu’il ne retrouve pas. Une exemption n’est jamais silencieuse, sans quoi le taux se mesurerait lui-même.

Ce dispositif a produit deux enseignements que je n’attendais pas. Le premier est que le bon indicateur n’est pas le taux de confirmation mais la **couverture** : un taux se règle en retirant une citation, une couverture non. Le jour où le périmètre est passé des trois quarts à la totalité des nombres publiés, cinq valeurs périmées sont apparues, et toutes venaient de la zone qui n’était pas contrôlée, aucune de la liste des non confirmés. Le second est que le chapitre qui portait la contribution centrale du mémoire n’était vérifié par rien : ses soixante-sept nombres étaient entièrement hors contrôle.

Deux choses que ce dispositif ne fait pas, et il faut les dire. Il ne vérifie pas qu’un nombre est au bon endroit ni qu’il veut dire ce que la phrase prétend : un nombre confirmé peut être mal commenté, et c’est exactement le défaut décrit au §6.3. Et il ne détecte pas les contradictions entre scripts : l’idée a été instruite puis écartée, parce que deux valeurs proches d’une même grandeur simulée se confirment légitimement l’une l’autre quand leur écart est inférieur au bruit, et parce qu’un détecteur de quasi-collision produirait des correspondances fortuites dans un ensemble de plusieurs milliers de nombres. Ce qui remplace ce contrôle est une convention de rédaction : toute grandeur simulée se publie avec son bruit.

4 La méthode

4.1 La cascade dirigée

Le mécanisme retenu est une cascade dirigée entre les cinq piliers. Un incident s’amorce sur un pilier, puis se propage aux autres selon une matrice d’influence W asymétrique, dont l’élément W_{jk} mesure l’intensité avec laquelle une défaillance du pilier j entraîne celle du pilier k . La ligne émet, la colonne reçoit, et cette convention est vérifiée par les scripts avant tout calcul, parce que l’intervertir donne un modèle différent qui produit les mêmes types de sortie.

La matrice n’est pas posée librement. Elle s’écrit

$$W(g) = \frac{g \text{TRANS}}{\max_l s_l}, \quad s_j = \sum_k \text{TRANS}_{jk}, \quad (1)$$

où TRANS porte la structure issue du corpus de rapports post-incident, où s_j est l’émission totale du pilier j , et où g est un gain global qui représente le niveau de non-conformité. C’est la normalisation de Leontief (Leontief, 1936), et la proposition 1 en donne la vertu.

Le choix du diviseur a été l’occasion d’une erreur instructive. Il doit être l’émission maximale, qui vaut 2,60 ; un script du projet divisait par la *réception* maximale, qui vaut 2,3. La

La propagation dirigée W : qui entraîne qui, et de combien

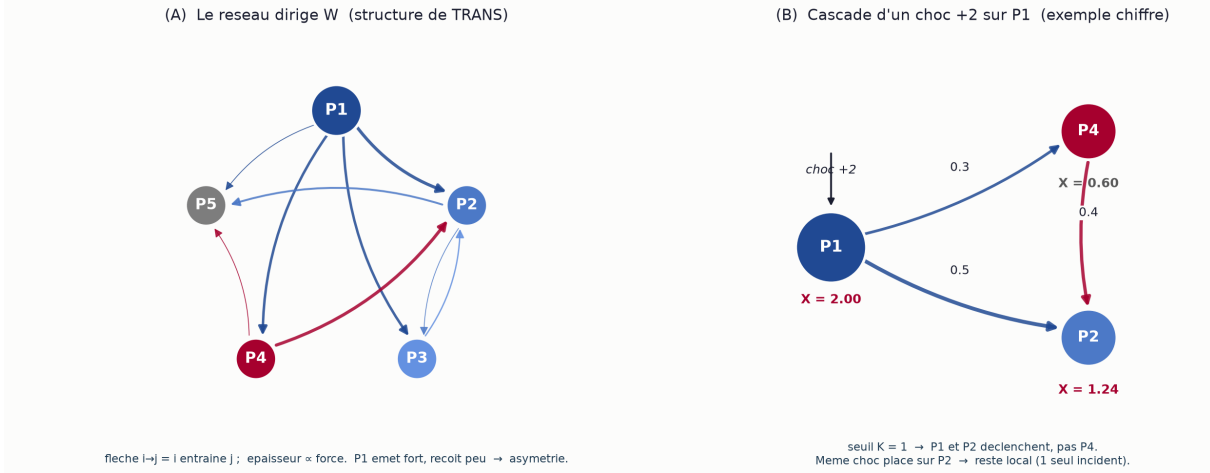


FIGURE 2. Le réseau dirigé issu du corpus de rapports post-incident (panneau A) et la propagation d'un choc unitaire sur P1 (panneau B). L'épaisseur d'une flèche est proportionnelle à l'intensité du transfert. P1 émet beaucoup et reçoit peu : c'est cette asymétrie qu'une dépendance symétrique ne peut pas représenter, et c'est elle qui commande l'ordre de remédiation.

différence paraît cosmétique et elle ne l'est pas : avec le diviseur de réception, le pilier P1 engendrait $0,9 \times 2,60/2,3 = 1,02$ descendants directs pour $g = 0,9$, c'est-à-dire *plus* que g . La borne que la normalisation existe pour poser était franchie, et g cessait de désigner ce qu'il désigne. La correction a fait baisser le taux de reproduction de base, qui vaut 0,054, et elle a renforcé la conclusion, puisqu'un taux plus petit décrit une cascade qui s'éteint plus vite.

Sources : scripts 03 (normalisation, rayon spectral, taux de reproduction) et 59 (convention de direction et matrice ordonnée).

4.2 Trois propriétés démontrées

Un modèle de contagion est facile à écrire et difficile à défendre, parce que ses propriétés intéressantes sont souvent celles qu'on a implicitement supposées. Trois propriétés sont donc démontrées, et une quatrième a été réfutée.

Proposition 1 (La normalisation borne la propagation). Sous (1), le nombre espéré de descendants directs du pilier j vaut $e_j = g s_j / \max_l s_l \leq g$, avec égalité pour le pilier le plus prolifique. De plus $\rho(W(g)) \leq g$. La cascade est donc sous-critique, et s'éteint presque sûrement, dès que $g < 1$.

Démonstration. Le premier point est un calcul direct : $e_j = \sum_k W_{jk} = g s_j / \max_l s_l$, et $s_j \leq \max_l s_l$. Pour le second, le rayon spectral d'une matrice à coefficients positifs est majoré par le maximum de ses sommes de lignes, donc par $\max_j e_j = g$. Un processus de branchement multitype de matrice moyenne W s'éteint presque sûrement dès que $\rho(W) < 1$. $\square$

La borne est confortable sur la structure calibrée, où le rayon spectral vaut $\rho(W(g)) =$

0,562 g , soit 0,506 à $g = 0,90$. Le gain critique au-delà duquel la cascade exploserait vaut donc 1,78, très au-dessus de toute la plage retenue. Un modèle de contagion qui n'énonce pas cette borne peut produire des explosions numériques qu'on prend pour des scénarios extrêmes.

La criticité dépend de l'ordre de la chaîne, non du seul ensemble des piliers touchés.

Deux incidents qui finissent par toucher les mêmes trois piliers ne coûtent pas la même chose selon l'ordre dans lequel ils les ont touchés, parce que le pilier atteint en premier conditionne la suite de la progéniture. Aucune structure de dépendance symétrique ne reproduit cette propriété : une copule affecte une probabilité à un *ensemble* de défaillances conjointes, et l'ordre n'y figure pas. C'est la justification formelle du choix de mécanisme, et elle remplace un argument d'opportunité.

La propriété réfutée. Le projet portait initialement sur la *non-transitivité* de la criticité, l'idée qu'un pilier P1 puisse dominer P2, P2 dominer P3, et P3 dominer P1, ce qui interdirait tout classement de priorité et constituerait un résultat frappant. Les tests l'ont écartée dans ses trois acceptions possibles. La propriété qui survit est plus faible et vraie, la dépendance à l'ordre, et c'est elle qui figure au mémoire. Renoncer au résultat frappant a été la décision la plus désagréable du stage et la plus formatrice : une propriété qui donne son titre à un travail crée une incitation à ne pas la tester sérieusement.

Le corpus corrobore la structure, et son biais est mesuré. La matrice vient d'un corpus de rapports post-incident codés à la main, ce qui soulève une objection immédiate : un rapport raconte une histoire, et une histoire a un sens de lecture, donc le codage pourrait ne mesurer que la convention narrative de ses auteurs. L'objection a été traitée par une loi nulle exacte plutôt que par une dénégarion : sous l'hypothèse d'un codage sans information directionnelle, l'asymétrie observée atteint un écart de 3,9 écarts-types, un jackknife montre qu'aucun rapport isolé ne porte le résultat, et le point de rupture est calculé.

Sources : scripts 03 (rayon spectral et gain critique), 64 (loi nulle du biais de narration, jackknife, point de rupture) et 75 (séquences ordonnées et dépendance à l'ordre).

4.3 L'état de conformité comme variable de pilotage

La conformité n'est pas un interrupteur unique. Chaque pilier porte son propre état, conforme ou non conforme, et ces états ne sont pas indépendants : une entité qui néglige un domaine en néglige souvent d'autres. Ils sont donc engendrés par une variable latente gaussienne à facteur commun, selon la construction utilisée en risque de crédit (Vasicek, 2002), avec une charge de facteur de 0,68 qui induit une corrélation de 0,462 entre deux piliers quelconques. Une couche markovienne fait évoluer ces états dans le temps, ce qui donne une *trajectoire* de besoin de capital plutôt qu'un chiffre unique (§5.4).

Cette construction a une conséquence qui n'était pas voulue et qui s'est révélée utile. La défaillance simultanée de plusieurs piliers n'est pas un cas non traité du modèle, c'est sa sortie, et elle est majoritaire à l'état non conforme : 62,31 % des sinistres y touchent plus d'un pilier, contre 31,15 % à l'état conforme, pour respectivement 1,931 et 1,380 pilier touché en moyenne. La loi du nombre de piliers touchés est obtenue par énumération exacte de la progéniture, donc sans bruit de simulation, et elle est citable telle quelle.

Sources : scripts 69 (structure de dépendance des états) et 74 (loi exacte du nombre de piliers touchés).

4.4 La frontière d'identifiabilité

Voici le point que je considère comme le résultat du stage. Toute matrice d'influence se décompose en une partie symétrique et une partie antisymétrique, $W = S + A$ avec $S = (W + W^\top)/2$ et $A = (W - W^\top)/2$. La donnée disponible identifie S , qui est la co-occurrence des défaillances, et ne dit rien de A , qui porte la direction. L'énoncé se démontre.

Proposition 2 (L'énergie de fluctuation est aveugle à la direction). Pour toute fonction test f sur les cinq piliers, la forme de Dirichlet

$$\mathcal{E}(f) = \frac{1}{2} \sum_{j,k} W_{jk} (f_k - f_j)^2$$

ne dépend de W que par sa partie symétrique S . En particulier W et $W^\top$ produisent la même énergie.

Démonstration. Par linéarité, $\mathcal{E}(f) = \mathcal{E}_S(f) + \mathcal{E}_A(f)$ avec $\mathcal{E}_A(f) = \frac{1}{2} \sum_{j,k} A_{jk} (f_k - f_j)^2$. En échangeant les indices muets j et k , cette dernière somme vaut $\frac{1}{2} \sum_{j,k} A_{kj} (f_j - f_k)^2$, soit $-\mathcal{E}_A(f)$, puisque $A_{kj} = -A_{jk}$ tandis que $(f_j - f_k)^2 = (f_k - f_j)^2$. Donc $\mathcal{E}_A(f) = 0$. $\square$

La conséquence est qu'une matrice et sa transposée sont indistinguables pour toute statistique construite sur cette énergie, alors qu'elles donnent un capital et une décision de remédiation différents. Ce n'est pas un problème de taille d'échantillon : plus de données de la même nature ne le lèveraient pas. C'est la propriété la plus utile du travail, parce qu'elle transforme un inconfort, l'impossibilité d'estimer la direction, en un énoncé vérifiable.

Trois sources ont été essayées et ont échoué pour des raisons *distinctes*, ce qui est plus solide qu'un échec unique : le schéma structuré ne renseigne les champs requis qu'une fois sur 10591, la chronologie temporelle ne permet pas de séparer une contagion d'une exposition commune, et même la meilleure expérience naturelle disponible ne conclut pas.

La troisième tentative méritait d'être menée jusqu'au bout. La meilleure expérience naturelle disponible est un incident de chaîne d'approvisionnement majeur, qui a touché simultanément un grand nombre d'organisations par un prestataire commun. La configuration est celle

qu'un économètre recherche : un choc daté, exogène aux victimes, et un groupe d'organisations exposées face à un groupe non exposé. Une estimation en différence de différences a donc été conduite, encadrée par les deux contrôles d'usage, un test placebo sur une date antérieure et un intervalle par bootstrap. Le résultat ne permet pas de conclure sur la direction, et l'exposer ainsi vaut mieux que de le taire : ce n'est pas la méthode qui manque, c'est que la donnée observe des *organisations* touchées et non des *domaines de contrôle* cédant l'un après l'autre. Aucun raffinement d'estimateur ne franchit cet écart, et c'est ce constat, répété sur trois sources, qui a fait basculer le travail vers l'identification partielle.

Sources : scripts 28 (champs du schéma structuré), 29 (frontière d'identifiabilité) et 35 (étude d'événement, placebo et bootstrap).

4.5 L'identification partielle

Plutôt que de poser une matrice arbitraire, la méthode caractérise l'**ensemble** des matrices compatibles avec la donnée et publie le capital en **bornes** sur cet ensemble. L'ensemble n'est pas approché : les $2^{10} = 1024$ sommets du polytope admissible sont énumérés exhaustivement.

Grandeur	Capital (M€)	Écart au socle
Socle identifié, toute direction annulée	5 275	référence
Direction nulle, co-occurrence seule		+51,5 %
Point d'expert, un point de l'ensemble	8 110	+53,7 %
Borne basse sur l'ensemble admissible	6 858	
Borne haute sur l'ensemble admissible	8 697	
<i>Largeur de la bande selon le degré d'ignorance t sur la direction</i>		
$t = 0,25$	336	
$t = 0,50$	695	
$t = 0,75$	1 083	
$t = 1$, état actuel de la donnée	1 839	

TABLE 2. Ce que l'information manquante coûte, gradué.

Lecture. Deux résultats en découlent, et ils sont plus favorables qu'un intervalle de confiance ordinaire. D'abord, **l'ignorance se paye linéairement et son coût maximal est connu d'avance** : on sait ce que coûterait de ne rien apprendre, ce qu'un estimateur ponctuel ne dit jamais. Ensuite, et c'est le plus important, **l'essentiel du surcoût de contagion ne vient pas de la direction** : la direction nulle donne déjà +51,5 % au-dessus du socle quand le point d'expert en donne +53,7 %. La co-occurrence, qui est identifiée, porte donc presque tout. La donnée manquante déplace la décision plus que le niveau, ce qui est exactement la raison de publier une hiérarchie de piliers plutôt qu'un chiffre.

Sources de la table : scripts 29 (socle identifié), 30 (bande graduée en t), 31 (point d'expert et effet d'un panel biaisé) et 32 (énumération des sommets et bornes).

Z : identification partielle de la contagion dirigée, et bornes de capital

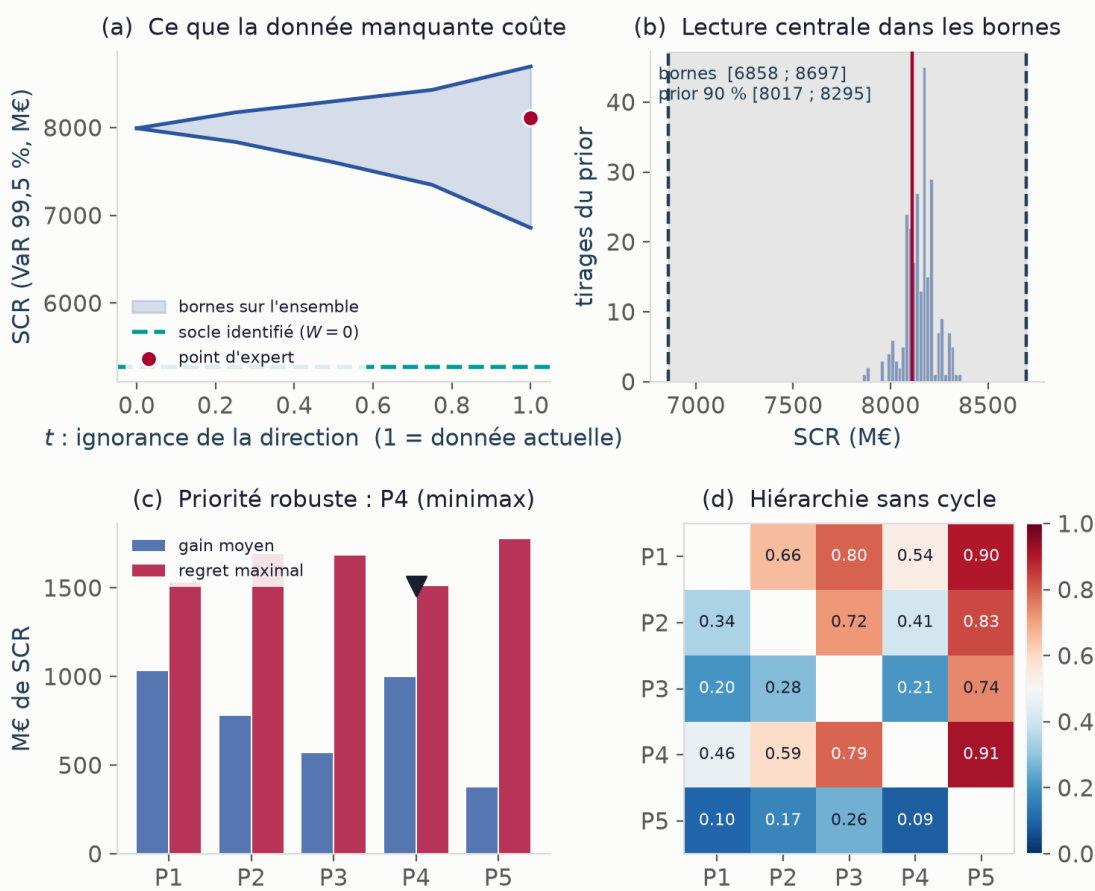


FIGURE 3. L'identification partielle en quatre lectures. (a) ce que la donnée manquante coûte, du socle identifié aux bornes complètes. (b) la lecture centrale placée dans les bornes. (c) la priorité de remédiation robuste au sens du regret maximal, qui désigne P4. (d) la hiérarchie obtenue, sans cycle.

4.6 Les quatre canaux de conformité

Le dernier élément de méthode est la façon dont la non-conformité entre dans le modèle, et c'est un point où il est facile de se tromper. La non-conformité n'ajoute *aucune* pénalité au capital : elle déplace quatre paramètres de la loi de perte, et le capital est recalculé.

Canal	Paramètre	Conforme	Non conforme	Statut
Fréquence	intensité annuelle λ	21,6	53,6	calibré
Détection	taux de dépassement p_u	0,128	0,181	calibré
Propagation	gain de cascade g	0,45	0,90	posé, borné
Accumulation	facteur tiers φ_{cs}	0	0,68	posé, borné

TABLE 3. Les quatre canaux que la conformité déplace.

Lecture. Deux canaux sont estimés sur donnée, deux sont posés puis encadrés par une analyse de sensibilité, et la distinction est reportée partout : on ne promet pas une remédiation là où

l'on n'a qu'une borne. Les trois valeurs du gain de propagation sont **posées et non calibrées**, et la thèse n'en dépend pas. Le capital est croissant en g , propriété démontrée et vérifiée numériquement, donc toute correspondance entre niveau de maturité et valeur de g qui respecte l'ordre produit l'écart, quand le forfait de la Formule Standard reste plat. Seule l'amplitude est un scénario.

Sources de la table : scripts 43 (les quatre canaux et leurs niveaux) et 66 (croissance du capital en g).

5 Résultats et critique

5.1 Le chiffre central et son encadrement

À structure de sévérité inchangée et sur les seuls quatre canaux, le besoin de capital passe de 6049 à 20188 M€ entre l'état conforme et l'état non conforme, soit un facteur 3,34 et un écart de 14139 M€.

Grandeur	Valeur	
Besoin de capital, état conforme sur les quatre canaux	6049	M€
Besoin de capital, état non conforme sur les quatre canaux	20188	M€
Facteur entre les deux états	3,34	
Écart	14139	M€
Somme des quatre canaux pris isolément	9138	M€
Somme des quatre effets de fermeture	19141	M€
Interaction, en résidu de la première	+5001	M€
Interaction, en part de l'écart	+35	%

TABLE 4. Le chiffre central, et l'encadrement qui l'accompagne.

Lecture. Le chiffre demande trois précautions, et ce sont elles qui le rendent citable. D'abord le **niveau est illustratif** : il varie d'un facteur 22 avec la seule source de sévérité retenue, et jusqu'à 41 en y ajoutant l'échelle de fréquence. Ce qui est défendu est le *rapport* entre les deux états, non le montant. Ensuite, la somme des canaux isolés et la somme des fermetures ne s'additionnent pas et ne doivent pas être resommées : elles *encadrent* l'écart, $9138 \leq 14139 \leq 19141$, et c'est là leur propriété. Enfin, ce chiffre est un besoin de capital économique calculé sur un périmètre notionnel, non un SCR réglementaire.

Quatre façons de chiffrer le même écart. Cette multiplicité a été un vrai problème de rédaction pendant plusieurs semaines : quatre protocoles donnaient de -53% à un facteur 3,34, parce qu'ils ne relâchent pas le même nombre de canaux. La lecture publiée est celle à quatre

canaux, et le motif du choix est qu'elle est la *seule* où l'état dit conforme est conforme sur tous les canaux du modèle : dans les trois autres, l'entité dite conforme propage encore, ou bien sa détection reste au niveau non conforme. Les trois autres lectures restent publiées comme des remédiations partielles, et leur emboîtement est lui-même un résultat.

Sources de la table : scripts 25 (lecture par score de conformité), 33 et 39 (facteurs d'amplitude du niveau), 43 (les deux états et le facteur), 67, section 3bis (table des quatre lectures), 68 (sommes isolée et de fermeture) et 82 (identité de la colonne de fermeture).

5.2 Attribution par canal et par pilier

Le résultat le plus utile en gestion n'est pas le montant mais sa décomposition, et elle se lit de deux façons complémentaires. Par *canal*, elle répond à la question « quel levier » ; par *pilier*, à la question « quel domaine de contrôle », qui est celle que pose un directeur des risques. Les deux sont des partitions du *même* écart et ne doivent jamais être additionnées, erreur que le titre d'une diapositive invitait à commettre et qui a été corrigée.

Canal	isolé	fermeture	Shapley
Fréquence	4 328 ± 463	8 775 ± 1 004	6 546 ± 457
Détection	1 448 ± 277	4 562 ± 819	2 928 ± 343
Accumulation	1 728 ± 210	3 402 ± 493	2 576 ± 222
Propagation	1 633 ± 188	2 402 ± 442	2 088 ± 152
<i>somme</i>	9 138	19 141	14 139

TABLE 5. Trois lectures d'un même canal, en millions d'euros, avec leur bruit de simulation. Isolée : effet du canal depuis l'état conforme. Fermeture : effet de sa remédiation depuis l'état non conforme. Shapley : attribution moyennée sur les ordres. Les deux premières sommes sont en italique parce que ces colonnes ne s'additionnent pas.

Lecture. La table porte une conséquence de gestion que je n'attendais pas : le rapport entre la colonne de fermeture et la colonne isolée va de 1,5 à 3,1 selon le canal, donc **remédier un canal rapporte davantage à une entité défaillante partout qu'à une entité déjà conforme par ailleurs**, puisque le canal ferme aussi les interactions qu'il portait. C'est la colonne de fermeture, et non l'isolée, qu'un plan de remédiation doit citer. Shapley est la seule colonne additive, mais c'est une *convention* d'attribution : deux canaux sur quatre étant des bornes posées, leur part n'est pas un budget.

La réconciliation est une identité, non une mesure : les quinze termes somment à l'écart à la précision machine, ce qui atteste que la table est *complète*, non que chaque terme est précis. Sur seize répétitions, neuf termes sur quinze ont un signe résolu, et aucun des cinq termes d'ordre trois et quatre. Une seule paire est négative, celle des deux canaux de co-occurrence, qui sont substitués et non compléments parce qu'un pilier déjà touché ne peut pas l'être deux fois : la

S24 : la table complète des quatre canaux, et où vivent les 5 001 M€ d'interaction

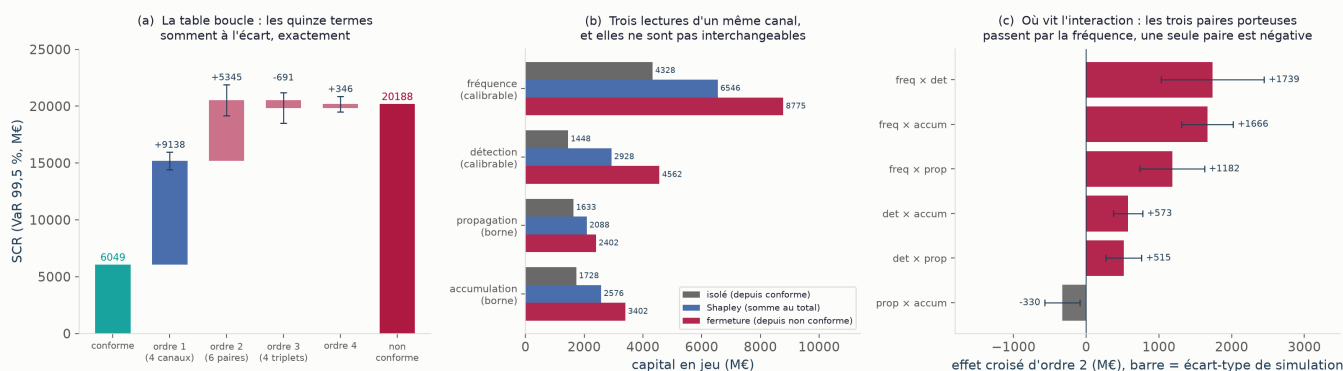


FIGURE 4. Décomposition complète des quatre canaux. (a) les quinze termes de la décomposition de Möbius somment exactement à l'écart : ordre 1 pour les canaux seuls, ordre 2 pour les paires, puis les ordres supérieurs. (b) les trois lectures d'un canal, non interchangeables. (c) les six effets croisés de paires avec leur bruit de simulation : les trois plus lourds passent tous par la fréquence, et un seul est négatif.

cascade est super-additive en bloc mais sous-additive entre ses deux canaux de co-occurrence, ce qui borne l'amplitude imputable à la contagion en général.

Pilier	Contribution (M€)	Rang
P1, gouvernance du risque lié aux technologies	3 524	1
P4, gestion du risque lié aux prestataires tiers	2 863	2
P2, gestion et notification des incidents	2 022	3
P3, tests de résilience	1 577	4
P5, partage d'informations sur les cybermenaces	897	5

TABLE 6. Attribution par pilier, par ajustement d'une forme additive en indicateurs sur les trente-deux configurations de conformité, avec $R^2 = 0,9945$.

Lecture. L'ordre reproduit celui des effets marginaux, et c'est cet ordre, plus que les montants, qui constitue la sortie décisionnelle du travail. La qualité de l'ajustement additif n'est pas un détail technique : elle a une conséquence, énoncée par la proposition 3.

Trois énoncés portent le même mot et donnent des réponses opposées. La confusion est facile et je l'ai commise avant de la lever. Premièrement, au sein d'un même sinistre, les coûts des piliers touchés s'additionnent : c'est une **hypothèse** de construction, et elle n'est pas testée. Deuxièmement, en fonction de l'ensemble des piliers non conformes, le capital est presque additif : c'est une **mesure**, celle du R^2 de la table 6. Troisièmement, en fonction des quatre canaux, il est franchement super-additif : c'est aussi une **mesure**, celle des 35 % d'interaction. Répondre « le modèle est super-additif » est donc faux : il l'est sur les canaux, pas sur les piliers, et l'hypothèse sur les coûts est un troisième objet.

Proposition 3 (L'espérance d'une forme additive ne dépend que des marges). Soit $X = (X_1, \dots, X_5) \in \{0, 1\}^5$ le vecteur des états de conformité et $K(X) = c_0 + \sum_j c_j X_j$ une forme additive en indicateurs. Alors

$$\mathbb{E}[K(X)] = c_0 + \sum_j c_j \mathbb{P}(X_j = 1),$$

quantité qui ne dépend que des lois marginales, jamais de la structure de dépendance entre les X_j .

Démonstration. Linéarité de l'espérance, puis $\mathbb{E}[X_j] = \mathbb{P}(X_j = 1)$ pour une variable de Bernoulli. $\square$

Cette proposition a réglé une objection d'encadrement. On m'avait fait remarquer, à juste titre, qu'être conforme aux piliers de gouvernance et d'incidents rend probablement un peu conforme au pilier de tests, et que cette dépendance particulière manquait au modèle. Répondre que la dépendance manque serait faux, puisque la latente à facteur commun induit déjà une corrélation de 0,462 entre deux piliers quelconques ; ce qui manque est sa *structure*, la dépendance modélisée étant échangeable quand le recouvrement des contrôles est propre à certains triplets. Or le capital s'ajuste par une forme additive à $R^2 = 0,9945$: la proposition s'applique donc en très bonne approximation, et l'invariance vaut pour *toute* structure à marges fixées, y compris celles qui n'ont pas été essayées. La mesure confirme : ajouter un surcroît de corrélation aux seules paires concernées, jusqu'à la limite de positivité de la matrice, déplace nettement la loi des configurations et ne déplace le capital espéré que de 2 M€, soit 0,02 %.

Et la réserve qui allait avec, chiffrée en fin de stage. L'invariance porte sur une *espérance*, comme la proposition le dit explicitement, et le mémoire le déclarait sans le mesurer. La mesure a été faite : l'espérance bouge de $-0,02\%$ quand le quantile à 75 % bouge de $+5,53\%$ et celui à 90 % de $+2,76\%$, par un mécanisme identifié qui est la **polarisation** des configurations à espérance inchangée. La réserve était donc justifiée, l'ordre de grandeur reste petit, et une limite de l'objet est apparue au passage : au-delà de 93,17 % le quantile *est* la configuration intégralement non conforme, donc les niveaux hauts sont saturés et un « quantile à 99,5 % de la loi des configurations » n'a aucun contenu.

Un point de vocabulaire sur l'allocation. L'attribution par valeur de Shapley et l'allocation d'Euler ne mesurent pas la même chose, et le mémoire le dit là où beaucoup de travaux les emploient indifféremment. Le noyau d'Euler, qui conditionne les pertes à leur dépassement du quantile, alloue une *moyenne de queue* et non le quantile lui-même. Il répartit donc un niveau déjà fixé, ce qui est légitime en diagnostic et ne l'est pas pour fixer un capital.

Sources : scripts 20 (interaction entre piliers), 43 et 68 (table des canaux, décomposition de Möbius, effets croisés), 69 (forme additive et invariance), 82 (identité de la colonne de fermeture

et définition d'Euler) et 94 (quantile de la loi des configurations).

5.3 Analyse de sensibilité

Un modèle de cascade attire une objection prévisible : tout dépendrait du niveau de contagion supposé, qui est précisément la partie posée. Deux analyses indépendantes montrent le contraire.

Paramètre	Élasticité	Statut
Indice de queue ξ	3,79	estimé
Échelle de sévérité σ	0,97	estimé
Taux de dépassement p_u	0,82	estimé
Intensité annuelle λ	0,45	estimé
Surdispersion φ	-0,44	posé
Gain de propagation g	0,37	posé
Seuil u	0,03	choix de méthode
<i>Ablation : ce que retirer une brique déplace</i>		
Queue lourde de la sévérité	-76,2 %	
Propagation dirigée	-20,3 %	

TABLE 7. Sensibilité de l'écart entre états, en élasticités à perturbation relative égale, puis en ablation de briques entières.

Lecture. À perturbation relative égale, l'indice de queue de la sévérité pèse dix fois le gain de propagation. **La fragilité du modèle est dans l'ajustement de valeurs extrêmes, pas dans la contagion**, ce qui est l'inverse de ce que l'on redoute d'un modèle de ce type, et les deux paramètres posés sont parmi les moins influents. Une seule élasticité est *négative*, celle de la surdispersion de la loi de comptage : augmenter la dispersion du nombre d'incidents *rétrécit* l'écart entre états, parce que l'écart est porté par un sinistre dominant unique et qu'une dispersion supplémentaire sur les comptes ajoute de la variance sans ajouter de queue. J'avais d'abord reporté sa valeur absolue, ce qui effaçait ce résultat. L'ablation, qui procède par un chemin indépendant, donne le même classement et une lecture que je n'avais pas anticipée : la forme de queue du capital agrégé est **héritée** de la sévérité, elle n'est pas produite par la cascade. La cascade change le nombre de piliers touchés, donc le montant par sinistre ; elle ne fabrique pas le caractère extrême de la distribution.

Cette analyse a demandé de refaire celle que j'avais produite d'abord, qui comportait deux défauts. Ses plages de variation n'étaient pas d'égale vraisemblance, ce qui rend un classement de barres non interprétable. Et l'un de ses leviers, le seuil de la loi de queue, *réajuste* trois autres paramètres quand les autres leviers n'en déplacent qu'un : il ne mesurait donc pas la sensibilité au seuil mais celle d'un paquet. Décomposé, le seuil seul ne déplace l'écart que de +320 M€ quand l'indice de queue seul le déplace de -13 993 : les composantes du paquet sont de *signes*

S32 : le tornado renormalisé, et ce que l'ancien classement devait à ses plages

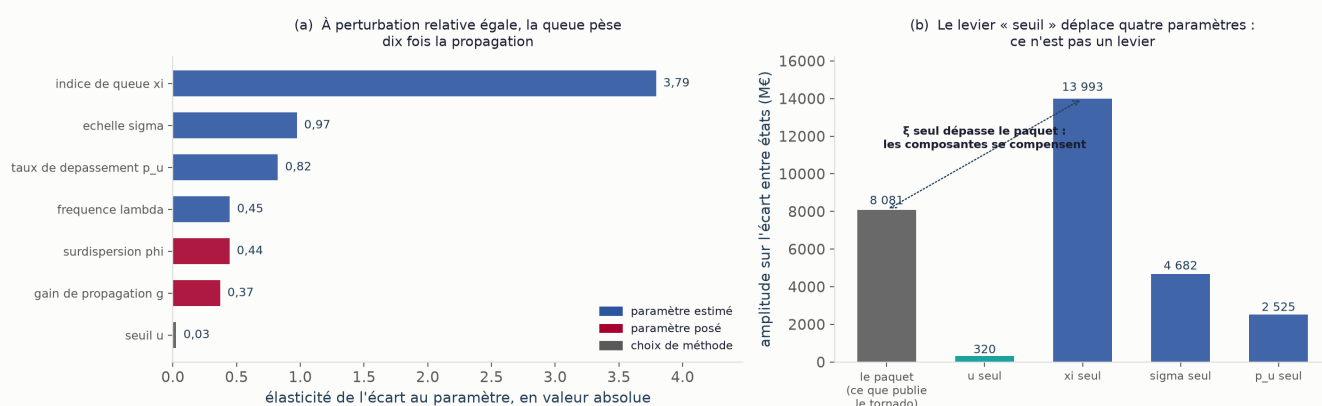


FIGURE 5. Sensibilité de l'écart entre états. (A) élasticités à perturbation relative égale, la couleur distinguant paramètre estimé, paramètre posé et choix de méthode. (B) décomposition du levier « seuil », qui déplace en réalité quatre paramètres à la fois.

opposés et se compensent, si bien que le paquet complet ne déplace l'écart que de -8081 . Un levier qui agrège des effets de sens contraires ne mesure pas une sensibilité, il en masque deux.

Ce résultat a une conséquence sur la façon de citer une source de la littérature. Un travail voisin, portant sur une cascade climatique, trouve que sa brique la plus lourde est la propagation dirigée, quand la nôtre est la queue. Les deux classements sont corrects chacun dans son modèle, et la cause de la divergence est dans leur propre texte : leur sévérité est *bornée*, donc sans indice de queue, et leur ablation ne contient aucune brique de queue. On ne retire pas ce qui n'est pas là. Ce travail est donc cité sur le protocole et jamais sur l'ordre du résultat, et une mention de convergence trop généreuse a été retirée du mémoire.

Sources de la table : scripts 15 (tornado initial), 76 (élasticités renormalisées et décomposition du levier de seuil) et 81 (ablation en échelle).

5.4 Trajectoire et durée de non-conformité

Puisque l'état de conformité évolue, le modèle produit une trajectoire de besoin de capital et non un point, ce qui permet de poser une question de gestion directe : que rapporte une remédiation qui aboutit en cours d'exercice ?

La réponse est contre-intuitive et elle interdit un raccourci répandu. Le capital est **concave** en la durée de non-conformité : un seul trimestre de non-conformité porte déjà 33 % du surcoût annuel, et remédier à mi-exercice ne rend que 44 % du bénéfice annuel, non la moitié. Un plan de remédiation qui prorata le gain au temps passé se trompe donc, et dans le sens optimiste. La raison est que la charge annuelle est portée par un sinistre unique, dont la probabilité d'occurrence croît vite au début de la période d'exposition puis sature.

Une seconde horloge, celle qui règle le délai entre l'amorce d'un incident et la défaillance des piliers suivants, a été testée par un effondrement à zéro. Elle ne coûte rien au résultat, dans

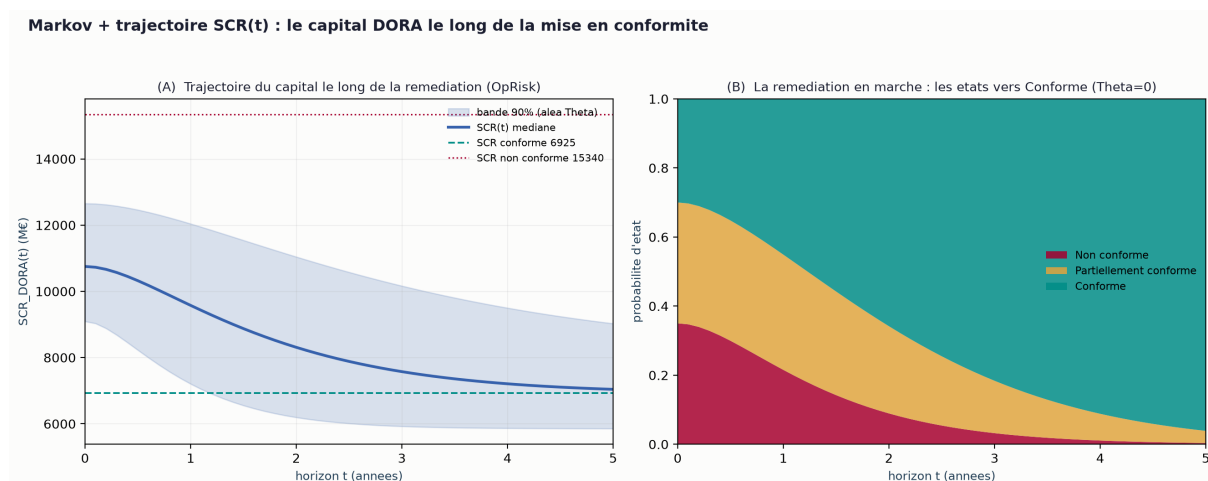


FIGURE 6. Trajectoire du besoin de capital le long d’une remédiation. (A) médiane et bande à 90 % du capital en fonction de l’horizon, entre les deux niveaux extrêmes. (B) probabilités d’état au cours du temps, de non conforme vers conforme. Les deux niveaux horizontaux du panneau (A) sont ceux de la lecture multi-états, qui ne relâche pas les mêmes canaux que la lecture publiée au §5.1 : leur amplitude est donc plus faible, et les deux lectures ne se substituent pas.

la limite du délai que la donnée soutient, ce qui justifie de ne pas la modéliser et d’écrire cette simplification au lieu de la laisser implicite.

Sources : script 79 (les deux horloges, concavité en durée).

5.5 Validation hors échantillon

Les tests de la figure 1 valident l’ajustement *dans* l’échantillon. Aucun d’eux ne demande au modèle de prédire une période qu’il n’a pas vue, et c’est la première question qu’un jury d’actuaire pose à un modèle de capital. Elle a été traitée en fin de stage par un backtest à origine glissante sur vingt-deux années, avec douze années notées. Le protocole ré-estime le seuil sur chaque échantillon d’apprentissage au lieu de le lire dans la configuration figée, sans quoi l’information de test fuiterait dans l’apprentissage.

Objet noté	Test	Résultat	Verdict
Loi du nombre d’incidents	couverture des intervalles, score logarithmique	binomiale négative 91,7 % contre 75,0 % pour Poisson, et gain au score que la largeur n’achète pas	VALIDÉ
Forme de la queue de sévérité	transformée probabiliste	non rejetée, $p = 0,4087$	VALIDÉ
Niveau de sévérité	Kupiec	quantiles dépassés trois fois trop souvent ; taux de dépassement $15,1 \rightarrow 27,1 \%$	REJETÉ
Charge annuelle agréée	Kolmogorov-Smirnov, couverture	$p = 0,0042$; couverture 75,0 % pour 90 % annoncés	REJETÉ

TABLE 8. Le backtest hors échantillon en quatre verdicts.

Lecture. Les deux premiers verdicts portent sur la *forme* des lois et ils passent; les deux derniers portent sur le *niveau* et ils échouent. Le motif est mesuré et il est unique : le taux de dépassement dérive dans le temps, donc l'échelle de sévérité n'est pas stationnaire. Un seul mécanisme est en défaut, et il produit trois symptômes, ce qui est très différent de trois défauts indépendants. En particulier le rejet de l'agrégat **n'est pas structurel** : la signature a été vérifiée avant de conclure, et le désalignement n'existe que sur la seconde moitié des années notées.

Ce résultat a été poursuivi plutôt que déclaré, et la suite a **modéré** la conclusion au lieu de l'aggraver. En modélisant la dérive d'échelle explicitement, on constate qu'elle n'est pas homogène le long de la distribution : le corps de la distribution dérive de 13,0% par an, la queue de 4,00% seulement, soit un facteur 3,2. L'effet à déclarer sur le quantile de sévérité est donc de +24,7%, et non le quintuplement que la dérive du corps suggérerait. La variante homogène a d'ailleurs été rejetée par un argument d'existence et non de degré : indexer toute la distribution sur la tendance du corps fait passer l'indice de queue au-dessus de un, ce qui détruit l'espérance de la sévérité.

Niveau de quantile	Années nécessaires
90 %	78
99 %	905
99,5 %, niveau réglementaire	1 811

TABLE 9. Puissance du backtest : nombre d'années d'observation nécessaires pour détecter, à 80 % de puissance, un taux de dépassement double du taux nominal.

Lecture. C'est le paragraphe qui vaut le plus devant un jury, et il va contre le confort. Le quantile qui porte le capital n'est backtestable sur *aucun* historique de risque opérationnel existant. Ce backtest valide le centre et le corps de la distribution, pas le niveau réglementaire, et un backtest qui ne déclare pas sa puissance laisse croire qu'une absence de rejet vaut validation.

Sources des tables : scripts 47 (tests dans l'échantillon), 89 (backtest de sévérité et dérive), 90 (effet de la dérive sur l'écart entre états) et 91 (backtest de la charge agrégée et puissance en années).

5.6 La règle de sélection du seuil

Le seuil est le paramètre le plus discrétionnaire d'un modèle de valeurs extrêmes, et un jury peut légitimement suspecter qu'il a été choisi pour son résultat. Trois règles de sélection ont donc été appliquées à l'aveugle sur dix percentiles candidats, ce qui représente seize mille ajustements.

Lecture. Le résultat est favorable et c'est la meilleure réponse possible au soupçon. La règle de stabilité retombe à 0,8% du seuil publié, pour un quantile identique; le seuil publié est le mieux ajusté de tout le balayage; et la règle la plus permissive donnerait un quantile **supérieur** de 16%, donc le seuil publié n'est pas celui qui maximise le chiffre du mémoire.

Règle	Seuil retenu	Effet sur le quantile
Stabilité de l'indice de queue sur son intervalle à 90 %	19,87 M€	quantile identique au publié
Meilleure adéquation d'Anderson-Darling du balayage	20,03 M€, le seuil publié	$p = 0,971$, contre 0,954 au second
Plus permissive, plus bas seuil non rejeté	12,88 M€	quantile supérieur de 16 %

TABLE 10. Trois règles de sélection du seuil, appliquées à l'aveugle.

Un résultat inattendu est apparu au passage, et il a fallu réécrire le commentaire : le compromis biais-variance que l'on écrit par habitude n'existe pas sur cette grandeur. Descendre le seuil dégrade *à la fois* le biais et la précision, parce que l'indice de queue gonfle jusqu'à 1,058 et que le quantile en dépend exponentiellement. Il n'y a donc rien à arbitrer, et le seuil se choisit sur l'adéquation et la stabilité seules.

Sources de la table : script 93 (les trois règles et le balayage).

5.7 Du secteur à l'entité

Tous les chiffres précédents sont sectoriels, parce que les bases de pertes le sont. Or la question posée est celle d'un assureur, donc il faut descendre d'échelle, et c'est l'endroit où une approximation commode se glisse le plus facilement.

Le repère habituel consiste à renormaliser le capital proportionnellement à la taille de l'entité, mesurée par son SCR de marché ou par ses primes. Cette opération affirme une **élasticité égale à un** de la perte à la taille. Les deux canaux par lesquels la taille agit ont été estimés séparément, et aucun n'en approche : la fréquence croît avec la taille selon une élasticité de 0,0744, d'écart-type 0,0098 donc très significativement différente de zéro mais d'un ordre de grandeur sous l'unité, et la sévérité selon une élasticité de 0,087 d'intervalle [0,026 ; 0,148]. La descente d'échelle retenue applique donc les deux élasticités mesurées, par un lien logarithmique pour la fréquence et par l'élasticité estimée pour la sévérité.

Le point le plus honnête de cette partie est l'encadré qui l'accompagne : **les deux approches se trompent en sens opposés**. La proportionnalité sous-estime une petite entité, puisqu'elle rétrécit une sévérité qui ne rétrécit pas. Le modèle la majore, puisqu'il ne plafonne pas la sévérité à l'exposition propre de l'entité. Substituer l'une à l'autre changerait donc le signe du défaut sans le déclarer, et c'est exactement ce qu'il ne faut pas faire. La proportionnalité au SCR de marché reste dans le mémoire comme le repère contre lequel la méthode se distingue, jamais comme une méthode de repli.

Le correctif identifié, un plafond de sévérité adossé à l'exposition propre de l'entité, a produit un résultat qui contredit l'intuition. On attendait qu'écarter chaque sinistre à une fraction de l'exposition borne le quantile annuel au même niveau, par le principe de la perte unique

dominante. C'est faux dès que le plafond mord, parce qu'écarter détruit la queue lourde que ce principe suppose : au plafond le plus serré essayé, le quantile simulé vaut le *double* du plafond. Un plafond ne fait donc pas tomber le capital à sa propre valeur, et il ne faut pas l'annoncer ainsi.

Sources : scripts 60 (élasticité de fréquence et descente d'échelle), 65 (bilans réels) et 78 (plafond adossé à l'exposition).

5.8 Application à quatre entités réelles

Le modèle a été descendu à l'échelle de quatre entités d'assurance réelles, à partir de leurs rapports de solvabilité publics. Les entités sont **anonymisées** dans le mémoire, par classes de taille, et la table de correspondance ne vit que dans un script : le modèle n'utilise que le bilan, jamais l'identité, et l'état de conformité y est supposé, donc nommer une entité lui attribuerait une non-conformité qui n'est pas observée.

La lecture de ces quatre rapports a corrigé une erreur de saisie de ma part, où un montant de fonds propres éligibles avait été pris pour un total d'actif, ce qui faisait passer la part attribuée à une entité de 41,3 à 16,7 %. Elle a aussi supprimé une limite déclarée, deux SCR étant en réalité publiés, et produit un résultat de comparaison : le forfait de risque opérationnel de la Formule Standard se trompe *dans les deux sens* face au module publié, de -8% chez l'une et de $+56\%$ chez l'autre, donc il ne constitue ni un majorant ni un minorant.

Le chiffre d'entité notionnelle, 169 M€, a été requalifié en **borne supérieure d'ordre de grandeur** et non en mesure, parce que l'entité tombe sous la borne inférieure de validité de la descente d'échelle. Cette borne de validité est publiée, ce qui est inhabituel et me paraît nécessaire : une méthode qui ne dit pas où elle cesse de valoir sera utilisée là où elle ne vaut pas.

Une figure a signalé l'anomalie de saisie avant que je la trouve : son panneau montrait une part qui *montait* avec la taille entre les deux petites entités, ce qui contredisait l'argument même de la section. La leçon vaut d'être retenue et elle revient au §6.3.

Sources : script 65 (bilans, SCR publiés, forfait comparé, borne inférieure de validité).

5.9 Inventaire des limites

Le mémoire consacre un chapitre entier à ses hypothèses, et le tableau qui le résume est organisé de façon à interdire une lecture rassurante.

Lecture. Cette présentation dit une chose que je tiens pour le résultat de méthode le plus important du stage : **la prudence du modèle ne vient pas de ses erreurs**. Elle vient de choix assumés, et corriger les trois écarts involontaires ne changerait aucune conclusion. Un inventaire de limites qui ne distingue pas les deux familles laisse penser que la marge de sécurité est un accident.

Écart ou choix	Taille mesurée	Sens sur le capital	Statut
<i>Écarts involontaires, tous trois anti-conservateurs</i>			
Incohérence du taux de dépassement, gelée	+2,4 % sur le quantile	sous-estime	ASSUMÉ
Couverture réelle des intervalles	86,8 % pour 90 % annoncés	sous-estime	ASSUMÉ
Dérive de l'échelle de sévérité	+24,7 % sur le quantile	sous-estime	ASSUMÉ
<i>Choix délibérés de prudence, qui majorent</i>			
Indice de queue posé au pire cas	$\xi = 0,90$	majore	ASSUMÉ
Surdispersion posée au moteur	$\varphi = 9,20$	majore	ASSUMÉ
<i>Hypothèses structurelles non testées</i>			
Additivité des coûts au sein d'un sinistre	écart de 9 706 à 20 487 M€	sens non déclarable	ASSUMÉ
Absence de plafond de sévérité d'entité	élasticité 0,087	majore le niveau d'entité	ASSUMÉ

TABLE 11. Inventaire des limites, par nature.

La ligne la plus lourde est l'additivité des coûts. Relâchée par un exposant sur le nombre de piliers touchés, elle déplace l'écart de 9 706 à 20 487 M€, soit 76 % de l'écart publié et quinze fois son bruit de simulation. Ce qui survit toute la plage est le signe et l'ordre de l'écart, non son amplitude ; ce qui ne se déclare pas est le *sens* de l'effet, deux mécanismes tirant en sens contraire. C'est la raison de citer l'élasticité, qui vaut pour toute amplitude, plutôt que la plage, qui ne vaut que pour celle-ci.

Sources de la table : scripts 47 (taux de dépassement), 63 (surdispersion et indice de queue posés), 65 (élasticité et niveau d'entité), 72 (couverture des intervalles), 74 (additivité des coûts) et 89 (dérive d'échelle).

5.10 Quelle grandeur reporter

Un modèle de capital ne produit pas un chiffre, il produit une famille de chiffres selon la façon dont on traite sa propre incertitude, et le choix de celui qu'on publie est une décision qui doit être motivée. Six postures ont été construites et mesurées.

Lecture. Deux constats, et le second n'était pas attendu. D'abord, intégrer l'incertitude d'estimation *ne déplace pas le point* : l'écart entre le quantile prédictif et le quantile aux paramètres estimés vaut 5 M€ en moyenne pour un bruit de simulation de 7. Ce qui est fragile n'est pas le point, c'est la largeur. Ensuite, les deux extrémités de l'échelle sont *exactes* et tout le bruit est au milieu : **une posture plus riche est moins reproductible, et la plus prudente est la moins précise**. Ce constat affaiblit en apparence la posture la plus rassurante, ce qui est exactement la raison de le publier. Il ne faut pas le surinterpréter pour autant : sur quatre rééchantillonnages un écart-type est lui-même connu à 40 % près, donc l'ordre entre les deux niveaux intermédiaires

Posture	Valeur (M€)	Bruit
Quantile aux paramètres estimés	662,78	exact
Quantile prédictif, incertitude d'estimation intégrée	648	± 7
Robuste au niveau $\beta = 90\%$	939	± 13
Robuste au niveau $\beta = 95\%$	1 037	± 9
Robuste au niveau $\beta = 99\%$	1 247	± 24

TABLE 12. Cinq des six postures, avec leur bruit de simulation. La sixième, un pire cas à indice de queue posé, est exacte par construction puisqu'elle ne repose sur aucune estimation.

n'est pas résolu et n'a pas à l'être.

La posture retenue, et la découverte qui ferme le débat. Le mémoire publie le quantile aux paramètres estimés *accompagné de sa bande*. Le motif est réglementaire et non d'opportunité : une borne haute sur un ensemble d'ambiguïté est un suprémum sur une famille de lois, non un quantile de la loi de perte, donc la substituer répond à une autre question que celle que pose Solvabilité II. Et une vérification a montré que le débat était en partie vide de contenu : la posture robuste au niveau de 95 % **est** la borne haute de l'intervalle à 90 % déjà publié, les deux valant 1 037 M€, parce qu'il s'agit de la même loi bootstrap lue à deux endroits. Reporter le point avec sa bande publie donc déjà le chiffre robuste, comme une borne et non comme un point.

Le niveau de l'intervalle. La question de reporter une bande à 90 ou à 95 % a été posée par l'encadrement académique. En allant chiffrer la réponse, j'ai constaté que le mémoire se contredisait lui-même, une annexe annonçant 95 % dans son ouverture et gardant 90 % dans sa conclusion deux pages plus bas. L'argument décisif y était déjà mesuré sans être lu : la couverture réelle vaut 86,8 % pour un niveau nominal de 90 et 91,8 % pour un nominal de 95, donc le manque est *le même*. Relever le niveau annoncé déplacerait l'annonce sans corriger l'estimateur.

Trois étages d'incertitude, à ne jamais fondre en une seule barre. Le bruit de simulation s'achète en temps de machine, puisqu'il décroît en racine du nombre d'années simulées. L'incertitude d'estimation ne s'achète pas, et elle est **dix fois plus grande** sur la même grandeur. L'ambiguïté de famille de loi est d'une troisième nature, épistémique : un choix de famille ne se moyenne pas. C'est le motif pour lequel cet étage a été sorti de la bande reportée et transformé en axe de sensibilité déclaré, alors qu'il est le plus gros des trois, avec un facteur 5,5 contre 2,5 pour l'incertitude de paramètre.

Une mesure de queue en diagnostic, jamais à la place du capital. Il m'a été demandé de traiter la moyenne de queue, mesure que beaucoup préfèrent au quantile. Elle est employée à deux titres, tous deux diagnostiques : comme noyau d'allocation, et comme indicateur de forme de queue par le rapport de la moyenne de queue au quantile, qui vaut 2,1 contre une asymptote théorique de 2,5. Elle ne porte aucun capital, et l'argument qui tranche n'est pas de degré mais d'**existence** : sous une source de sévérité alternative, l'indice de queue estimé vaut 1,033, donc supérieur à un, donc l'espérance est infinie et la mesure *n'existe pas*. Une mesure de couverture qui cesse d'être définie selon la base retenue ne peut pas porter une exigence de capital. Accessoirement, une moyenne de queue au niveau de 95 % vaudrait 5734 M€ contre 8374 pour le quantile réglementaire : rapportée comme capital, elle serait *moins* prudente que l'exigence, ce qui n'est pas l'intuition courante.

Sources : scripts 46 et 51 (postures et leur bruit), 48 (bande de modèle et trois étages), 72 (niveau de l'intervalle), 73 (moyenne de queue en diagnostic) et 84 (origine de la largeur des intervalles).

5.11 Mise en regard des cadres existants

Le travail se compare à trois références, et aucune des trois comparaisons ne tourne comme on l'attendrait.

Le forfait réglementaire, d'abord, ne borne rien : il se trompe dans les deux sens face aux modules publiés (§5.8), donc il est à citer comme ordre de grandeur et jamais comme majorant ni minorant.

Supposer une queue commune à toutes les catégories de risque opérationnel sous-estime le capital. La table des indices de queue par catégorie, recalculée avec un filtre écrit après que la précédente s'est révélée irreproductible, donne des valeurs allant de 0,865 à 1,368 pour une dispersion de 0,50. Traiter la catégorie technologique comme les autres conduirait donc à une borne de capital inférieure de plusieurs dizaines de pour cent, et la conclusion du chapitre concerné en sort renforcée plutôt qu'affaiblie.

Le modèle voisin le plus naturel n'est pas distinguable du nôtre, et c'est un résultat. Les processus auto-excités sont l'outil canonique pour représenter une contagion d'incidents, et le travail les écarte. Le motif a changé en cours de route et le nouveau est plus solide : une cascade sans *aucune* auto-excitation reproduit le ratio de branchement mesuré à la journée, 0,480 contre 0,551, et retrouve même la demi-vie observée. Le ratio mesuré ne prouve donc rien quant au mécanisme, et le choix entre les deux modèles est un choix de parcimonie interprétative, pas un rejet statistique. Formuler ainsi est plus faible et vrai, alors que la formulation initiale, qui annonçait un rejet, prêtait le flanc à une objection immédiate. Une précaution y est attachée : dégrader la résolution temporelle *augmente* le ratio mesuré, donc deux études qui n'agrègent

pas au même pas ne se comparent pas.

Sources : scripts 37 (indices de queue par catégorie), 65 (forfait comparé aux modules publiés), 67, section 5 (table des queues) et 85 (équivalence observationnelle).

5.12 Lecture économique

Le dernier volet met l'écart de capital en regard de son coût. Détenir du capital coûte chaque année un pourcentage du montant immobilisé, donc libérer 14 139 M€ économise 848 M€ par an au taux historique de 6 %, et non une fois. Le mémoire écrivait initialement que le *retour sur investissement* était un plancher, alors que ce qui est minoré est le *bénéfice*, et que minorer un bénéfice *maigre* une durée : le sens de la borne était inversé, dans le texte, dans le script et dans le titre d'une figure. La correction a été faite aux trois endroits.

Le bénéfice a deux composantes et une seule est monétisée dans le chiffre publié. Le portage vaut 848 M€ par an, la sinistralité évitée en vaut 3 247, soit 3,8 fois plus. L'affirmation « le bénéfice est majoritairement de la perte évitée » figurait dans le document depuis le début sans être chiffrée ; elle l'est désormais, et elle change la conclusion : au portage seul, le seuil de rentabilité tombe sous le coût haut d'un programme de conformité, donc le projet ne se rentabilise *jamais* à ce niveau de coût, et le « retour en trente-cinq ans » masquait une non-existence. Ce qui rentabilise la conformité est la perte évitée, qui cesse ainsi d'être une précaution de rédaction pour devenir la condition de rentabilité.

Un résultat annexe mérite d'être cité parce qu'il est net : le transfert du risque à un réassureur reste préférable à sa détention tant que plus de 78 % de la couverture ne sont pas inefficaces, ce qui est une marge considérable.

Sources : scripts 50 (portage, sinistralité évitée, sens de la borne), 58 (seuil d'inefficacité du transfert) et 83 (formule du retour actualisée).

6 Enseignements du stage

6.1 Les enseignements de l'ENSAE mobilisés

Le sujet a mobilisé la formation de façon assez directe, et sur plusieurs enseignements à la fois, ce qui est la difficulté propre d'un travail de modélisation complet.

Lecture. L'apport le plus décisif n'est pas celui que j'attendais. C'est l'économétrie de l'identification : reconnaître qu'un paramètre n'est *pas identifié*, plutôt que constater qu'il est mal estimé, est un réflexe qui vient de ce cours, et il a changé la nature du mémoire. La différence est considérable en pratique, puisqu'un paramètre mal estimé appelle plus de données quand un paramètre non identifié appelle une autre méthode. Vient ensuite la lecture de l'indice de queue comme condition d'existence des moments, qui a permis de rejeter deux variantes par un argument d'existence plutôt que de degré.

Enseignement	Ce qu'il fournit au travail	Où
Statistique des valeurs extrêmes	dépassements de seuil, ajustement de Pareto généralisé, et surtout l'indice de queue lu comme condition d'existence des moments	§3.4, §5.6
Modèles à variable latente gaussienne	dépendance entre états de conformité, transposée du risque de crédit	§4.3
Processus stochastiques et chaînes de Markov	dynamique des états, trajectoire de capital, processus de branchement	§4.2, §5.4
Statistique inférentielle et théorie des tests	adéquation, tests de couverture, bootstrap paramétrique, puissance	§3.4, §5.5
Économétrie de l'identification	identification partielle, ensemble admissible, capital en bornes	§4.4, §4.5
Économétrie de l'évaluation	différence de différences, test placebo, bootstrap	§4.4
Méthodes de Monte-Carlo	lois de perte simulées, et la discipline de publier un bruit	§5.2, §5.10
Théorie des jeux coopératifs	valeur de Shapley pour l'attribution par canal	§5.2
Assurance non-vie et Solvabilité II	charge de capital, quantile réglementaire, marge de risque, allocation	§2.2, §5.12
Programmation scientifique	une centaine de scripts reproductibles et leurs sorties versionnées	§3.5, §3.6

TABLE 13. Les enseignements mobilisés et l'endroit du rapport où chacun sert.

Deux compétences non mathématiques ont compté autant. La programmation scientifique, parce qu'une centaine de scripts qui doivent tous rester reproductibles pendant des mois est un problème d'ingénierie et non de calcul. Et la rédaction, parce que la moitié du travail effectif a consisté à écrire des énoncés qui ne dépassent pas ce que le calcul soutient.

6.2 La part de l'encadrement et des tiers

Cette section est demandée par les consignes et je la prends au sérieux, parce que plusieurs résultats de ce travail ne seraient pas là sans une remarque extérieure. Le suivi s'est fait par un point hebdomadaire, préparé sous forme d'un jeu de diapositives et donnant lieu à des demandes précises.

Lecture. Aucune de ces demandes ne portait sur un calcul, et toutes ont fait tomber un défaut. C'est le constat que je retiens de l'encadrement : la valeur d'une relecture extérieure ne tient pas à sa compétence technique sur le détail, elle tient à ce qu'elle interroge un énoncé hors du contexte qui le justifiait.

L'orientation du traitement des processus auto-excités mérite une mention particulière, parce que le domaine de recherche de l'encadrement académique est précisément celui-là. Le rejet de cet outil a été testé contre *leurs* variantes de noyau et non contre un modèle de paille, et il s'est

Demande ou remarque	Ce qu'elle a changé dans le travail
Retirer les conclusions tirées du bootstrap de l'indice de queue, un intervalle trop large ne portant pas de conclusion	l'intervalle reste affiché comme un fait, la lecture qu'on en faisait disparaît ; et le retrait a fait tomber une valeur fausse d'une diapositive antérieure
Soupçon de double comptage dans la colonne de fermeture	soupçon infondé, la somme des fermetures étant une identité ; mais une ligne « somme » sous une colonne non additive invitait cette lecture, et elle a été retirée
Demande d'une table complète des leviers	la table 5 et la découverte de l'effet de fermeture, qui change le chiffre qu'un plan de remédiation doit citer
Deux mots mal employés, « portage » et « plancher »	le sens d'une borne était inversé, dans le texte, dans un script et dans un titre de figure ; corrigé aux trois endroits
« Le quantile d'un objet incertain est un mauvais estimateur »	le quantile prédictif et la bande de modèle ; résultat contraire à l'attente, puisque c'est la largeur et non le point qui était fragile
Traiter la moyenne de queue	mesure de queue en diagnostic, et l'argument d'existence qui interdit de la substituer au quantile
Sensibilité aux probabilités de propagation	la section 5.3, dont le résultat va contre l'inquiétude qui la motivait

TABLE 14. Les demandes de l'encadrement et leur effet sur le travail.

reformulé en cours de route en équivalence observationnelle suivie d'un choix de parcimonie (§5.11). Cette reformulation est plus faible en apparence et plus honnête, et c'est celle qui tient.

Les tiers. Un collègue du cabinet a été sollicité pour un second codage en aveugle du corpus de rapports post-incident, destiné à mesurer la fiabilité entre codeurs. Ce codage n'était pas reçu à la date de rédaction, et le dispositif d'accueil est prêt et testé sans produire aucune donnée en son absence. Le mémoire déclare explicitement que ce second codage n'est pas le préalable du résultat mais son renforcement, et ce qu'il apporterait est une mesure d'intersubjectivité, non une correction de niveau. Par ailleurs, une étude de marché du cabinet, dont j'ai co-écrit l'analyse actuarielle, est citée dans l'introduction du mémoire comme source externe non recalculable, avec le garde-fou d'échelle qui interdit de comparer une charge indemnisée de marché à une perte brute d'entité.

Sources : scripts 46 (quantile prédictif), 08h (variantes de noyau) et 85 (équivalence observationnelle).

6.3 Ce que j'en retiens

Écrire le commentaire après avoir lu la sortie, jamais en même temps que le code qui la produit. C'est la leçon la plus coûteuse et je l'ai apprise sept fois. Sept fois j'ai rédigé une conclusion pendant que le calcul tournait, et sept fois la sortie l'a démentie : un effet annoncé

convexe qui était concave, un écart annoncé en train de se refermer qui grossissait, un ratio annoncé en effondrement qui montait, une dépendance annoncée conservatrice que le contrôle suivant a niée, et le compromis biais-variance du §5.6, que la colonne d'écart-type a exactement renversé. Le mécanisme est toujours le même : on écrit ce que l'on attend, et le texte survit à la mesure parce que personne ne le relit contre elle.

La couverture passe avant le taux. Un indicateur de qualité qui se calcule sur un périmètre choisi mesure le périmètre autant que la qualité. Le dispositif de vérification affichait 99,6 % de nombres confirmés sur un périmètre qui ne couvrait que 74,7 % des nombres publiés, et les valeurs périmées vivaient toutes dans le quart restant. Un taux se règle en retirant une citation, une couverture non. Je crois que cette asymétrie est générale et qu'elle vaut bien au-delà de ce projet.

La figure est le meilleur détecteur de défauts. Les erreurs trouvées pendant ce stage ne l'ont presque jamais été en relisant le texte. Elles l'ont été en regardant une figure ou une diapositive et en allant vérifier ce qu'elle affirmait : un seuil contradictoire, six postures affichées dont deux n'étaient définies nulle part, une même grandeur à deux valeurs, un facteur calculé à la main et jamais imprimé, et l'anomalie de bilan du §5.8, qu'un panneau croissant a signalée avant que je la cherche. Une figure force à énoncer un chiffre hors du contexte qui le justifiait, et c'est là qu'un défaut devient visible.

6.4 Ce que je ferais autrement

Deux choses. J'aurais mis le dispositif de vérification en place au début et non au milieu : construit après coup, il a fallu rattacher chaque section du document à ses scripts, et c'est ce rattrapage qui a révélé que le chapitre central n'était contrôlé par rien. Et j'aurais gelé la calibration plus tôt. Le gel a été décidé à mi-parcours, après plusieurs semaines où des recalibrations partielles faisaient bouger des nombres déjà écrits, ce qui est la façon la plus efficace de perdre une piste d'audit.

7 Conclusion

Le point d'arrivée est un modèle complet, documenté et vérifié, qui traduit un niveau de non-conformité à DORA en une distribution de pertes puis en un besoin de capital, et qui publie cette traduction sous la forme d'un écart entre états plutôt que d'un niveau. Sur les quatre canaux que la conformité déplace, cet écart vaut 14 139 M€ au périmètre sectoriel, soit un facteur 3,34, dont 35 % ne sont attribuables à aucun canal pris isolément mais à leurs interactions. La hiérarchie des piliers est stable là où le niveau ne l'est pas, et c'est elle qui porte la lecture décisionnelle.

Ce qui a pu être réalisé, au-delà du chiffre, tient en trois choses. Un mécanisme dont les propriétés sont démontrées et non supposées, avec une stabilité garantie par construction (proposition 1). Une frontière d'identifiabilité établie, c'est-à-dire une démonstration que la direction de la propagation ne s'estime pas sur la donnée disponible (proposition 2), suivie de la méthode qui en tire parti : borner le capital sur l'ensemble admissible et chiffrer en euros ce que l'information manquante coûte. Et un dispositif de vérification qui rattache chaque nombre publié au calcul qui le produit, sur la totalité du document.

Ce qui n'a pas pu l'être doit être dit avec la même précision. Le second codage en aveugle du corpus n'a pas été reçu, donc la fiabilité entre codeurs n'est pas mesurée, et le mémoire déclare que ce codage renforcerait l'énoncé sans le conditionner. L'éllicitation d'experts a été préparée puis abandonnée, avec son motif chiffré plutôt que par manque de temps : un panel faiblement calibré déplacerait le capital de plusieurs centaines de millions d'euros sans qu'aucun signal ne l'indique, là où l'approche par bornes reste invariante ; le protocole complet est en annexe du mémoire comme actif réversible. Le plafond de sévérité adossé à l'exposition d'une entité est identifié et chiffré mais non implémenté, parce qu'il déplacerait tous les résultats d'entité et relève donc de la recalibration interdite par le gel. Enfin, l'agrégation de ce besoin de capital aux autres modules d'un SCR n'a pas été traitée.

Trois prolongements me paraissent utiles, de valeur décroissante. Le plus utile n'est pas mathématique : c'est le registre d'incidents mieux spécifié, puisque le travail chiffre en euros ce que sa seule absence coûte et que le champ nécessaire existe déjà dans les schémas de la profession. Vient ensuite la levée de l'hypothèse d'additivité des coûts, la plus lourde des hypothèses non testées, puis l'articulation avec les autres modules de capital.

Sur le plan personnel, ce stage m'a moins appris à construire un modèle qu'à délimiter ce qu'un modèle autorise à dire. Le travail a réfuté la propriété qui lui donnait son titre et requalifié son chiffre central en borne, et il vaut mieux ainsi : un document qui publie ses propres limites se défend, alors qu'un document qui les dissimule attend qu'on les trouve.

Sources : scripts 31 (effet d'un panel biaisé), 43 et 68 (écart et interaction) et 78 (plafond chiffré, non implémenté).

Références

- Règlement (ue) 2022/2554 du parlement européen et du conseil sur la résilience opérationnelle numérique du secteur financier (dora), 2022.
- August A. Balkema and Laurens de Haan. Residual life time at great age. *The Annals of Probability*, 2(5) :792–804, 1974.
- Yannick Bessy-Roland, Alexandre Boumezoued, and Caroline Hillairet. Multivariate hawkes process for cyber insurance. *Annals of Actuarial Science*, 15(1) :14–39, 2021.

- Alexandre Boumezoued, Yousra Cherkaoui, and Caroline Hillairet. Cyber risk modeling using a two-phase hawkes process with external excitation, 2023. arXiv :2311.15701.
- Martin Eling and Jan Wirfs. What are the actual costs of cyber risk events? *European Journal of Operational Research*, 272(3) :1109–1119, 2019.
- Paul Embrechts, Claudia Klüppelberg, and Thomas Mikosch. *Modelling Extremal Events for Insurance and Finance*. Springer, 1997.
- Hemantha Herath and Tejaswini Herath. Copula-based actuarial model for pricing cyber-insurance policies. *Insurance Markets and Companies*, 2, 2011.
- Caroline Hillairet and Olivier Lopez. Propagation of cyber incidents in an insurance portfolio : counting processes combined with compartmental epidemiological models. *Scandinavian Actuarial Journal*, 2021.
- Bertrand Iooss and Clémentine Prieur. Shapley effects for sensitivity analysis with correlated inputs : Comparisons with Sobol’ indices, numerical estimation and applications. *International Journal for Uncertainty Quantification*, 9(5) :493–514, 2019. doi : 10.1615/Int.J.UncertaintyQuantification.2019028372.
- Wassily Leontief. Quantitative input and output relations in the economic system of the united states. *The Review of Economics and Statistics*, 18(3), 1936.
- Charles F. Manski. Nonparametric bounds on treatment effects. *American Economic Review*, 80(2) :319–323, 1990.
- James Pickands III. Statistical inference using extreme order statistics. *The Annals of Statistics*, 3(1) :119–131, 1975.
- Lloyd S. Shapley. A value for n -person games. In Harold W. Kuhn and Albert W. Tucker, editors, *Contributions to the Theory of Games, Volume II*, number 28 in Annals of Mathematics Studies, pages 307–317. Princeton University Press, 1953.
- Elie Tamer. Partial identification in econometrics. *Annual Review of Economics*, 2 :167–195, 2010. doi : 10.1146/annurev.economics.050708.143401.
- Oldrich Vasicek. The distribution of loan portfolio value. *Risk*, 2002.

A Les paramètres du modèle

Grandeur	Valeur	Statut	Origine
Seuil de sévérité u	20,03 M€	calibré, gelé	percentile de la base filtrée
Excès au seuil	91	compté	base filtrée
Indice de queue $\hat{\xi}$	0,5954	estimé	maximum de vraisemblance
Échelle $\hat{\sigma}$	57,97	estimé	maximum de vraisemblance
Intensité annuelle λ	21,6 à 53,6	calibré	chronologie d'incidents
Taux de dépassement p_u	0,128 à 0,181	calibré, gelé	base filtrée
Gain de propagation g	0,45 / 0,68 / 0,90	posé	scénarios de maturité
Facteur tiers φ_{cs}	0 à 0,68	posé	scénarios
Charge de facteur commun	0,68	posé	pratique du risque de crédit
Rayon spectral $\rho(W)$	0,506	calculé	structure du corpus
Taux de reproduction R_0	0,054	calculé	structure du corpus
Gain critique	1,78	calculé	structure du corpus

TABLE 15. Les paramètres, avec la distinction qui compte : ce qui est estimé sur donnée, ce qui est posé en scénario, et ce qui est gelé depuis le 7 août 2026.

Lecture. C'est le tableau qu'un lecteur devrait consulter en premier, et sa colonne de statut est plus informative que sa colonne de valeur : elle dit où le modèle s'appuie sur une mesure et où il s'appuie sur un choix. La thèse ne dépend d'aucune des valeurs posées, seulement de leur ordre, et c'est ce que la table 7 vérifie en montrant que les deux paramètres posés sont parmi les moins influents.

Sources de la table : scripts 03 (rayon spectral, taux de reproduction, gain critique), 07 (ajustement de sévérité), 08b (fréquence et dispersion), 43 (niveaux des quatre canaux), 47 (seuil et excès), 60 (intensité annuelle), 63 (calibration figée) et 67 (paramètres posés).

B Chronologie du stage

Période	Jalon
Premières semaines	Cadrage du sujet, revue de littérature, construction de la chaîne de calcul, premières calibrations de sévérité et de fréquence.
Puis	Bascule du modèle vers la cascade dirigée, au détriment d'une approche par copule et facteur latent statique, sur validation de l'encadrement.
Puis	Démonstration de la frontière d'identifiabilité, puis construction de l'identification partielle et énumération exhaustive de l'ensemble admissible.
Mi-parcours	Réfutation, par mes propres calculs, de la non-transitivité qui donnait son titre au projet ; remplacement par la dépendance à l'ordre.
7 août 2026	Gel de la calibration. À compter de cette date, seules les corrections d'erreur sont autorisées.
Puis	Mise sous contrôle de la totalité des nombres publiés ; lecture des quatre rapports de solvabilité et requalification du chiffre d'entité en borne supérieure.
Fin de stage	Premier backtest hors échantillon du projet, sur la sévérité puis sur la charge agrégée ; règle de sélection du seuil ; test de résistance inversé sur les quatre canaux.

TABLE 16. Les jalons du stage. Les deux dates qui ont le plus compté sont celle du gel de la calibration et celle de la mise sous contrôle complète des nombres publiés.

Note de synthèse

Le problème. Depuis janvier 2025, le règlement européen DORA impose aux banques et aux assureurs la maîtrise de cinq domaines de résilience informatique : gouvernance du risque technologique, gestion des incidents, tests de résilience, maîtrise des prestataires tiers, partage d'informations sur les menaces. Le règlement dit ce qu'il faut mettre en place. Il ne dit pas ce que coûte de ne pas le faire, et le cadre prudentiel qui fixe le capital d'un assureur, Solvabilité II, ne le dit pas non plus : sa charge de risque opérationnel est un pourcentage des primes, identique pour un assureur exemplaire et pour un assureur défaillant. Un dirigeant qui arbitre un budget de conformité ne dispose donc d'aucun chiffre.

La difficulté, qui n'est pas celle qu'on croit. Les cinq domaines ne sont pas des cases indépendantes. Une gouvernance défaillante retarde la détection des incidents, et un prestataire mal maîtrisé ouvre une porte que les tests n'ont pas explorée : la défaillance se propage, et dans un sens. Un domaine en entraîne d'autres, et il vaut mieux corriger une cause qu'un symptôme. Les outils statistiques habituels représentent le fait que plusieurs domaines cèdent ensemble, mais pas lequel a entraîné l'autre, alors que c'est ce sens qui devrait dicter l'ordre des travaux.

Ce qui a été construit. Le travail représente la propagation par une *cascade dirigée* : un incident naît sur un domaine, puis se transmet aux autres selon une matrice d'influence asymétrique, calibrée sur un corpus de rapports d'incidents officiels et normalisée de sorte que la cascade s'éteigne toujours. L'état de conformité, domaine par domaine, pilote alors quatre paramètres de la loi des pertes : combien d'incidents surviennent par an, quelle proportion échappe à la détection, avec quelle force ils se propagent, et dans quelle mesure un prestataire commun les fait converger. Le capital est recalculé à partir de cette loi, sans pénalité ajoutée.

Le résultat principal. Entre un état pleinement conforme et un état pleinement défaillant,

le besoin de capital est multiplié par 3,3. Surtout, les quatre canaux ne s'additionnent pas : pris séparément ils expliquent les deux tiers de l'écart, et le tiers restant, environ 35 %, vient de leurs interactions. Conséquence directe : corriger un domaine rapporte davantage à une entité défaillante partout qu'à une entité déjà saine par ailleurs, parce que la correction ferme aussi les interactions que ce domaine portait. Le chiffre à citer dans un plan d'action est donc l'effet de fermeture, de 1,5 à 3 fois plus grand que l'effet isolé.

L'apport de méthode, et il est plus important que le chiffre. La donnée disponible ne permet pas d'observer le *sens* de la propagation, et ce n'est pas un manque de volume : la grandeur observable y est mathématiquement insensible, donc une matrice et son symétrique sont indiscernables pour la donnée tout en conduisant à des décisions différentes. Un schéma d'incidents standard de la profession porte les deux champs nécessaires et ne les renseigne ensemble que dans un incident sur 10591. Le travail ne pose donc pas une valeur arbitraire : il calcule l'*ensemble* des matrices compatibles avec la donnée et publie le capital en fourchette. L'ignorance a ainsi un coût connu d'avance et plafonné, et l'essentiel du surcoût vient de la co-occurrence des défaillances, qui est observable, non du sens de la propagation. Ce sens manquant déplace la *priorité* de remédiation plus que le montant, d'où une hiérarchie de domaines plutôt qu'un chiffre.

Les limites, publiées avec le résultat. Le niveau absolu du capital est illustratif : il varie fortement selon la base de sinistres retenue, et c'est le rapport entre les deux états qui est défendu. Un backtest hors échantillon valide la loi du nombre d'incidents et la forme de la queue des pertes, mais montre que le niveau des pertes extrêmes dérive plus vite que le modèle ne le suppose, donc que le capital est sous-estimé. Ce même backtest chiffre enfin sa propre puissance : détecter une anomalie sur le quantile réglementaire demanderait plus de mille huit cents années d'observations, donc aucun historique existant ne permet de valider ce niveau.

Executive summary

The problem. Since January 2025, the European DORA regulation has required banks and insurers to master five areas of digital operational resilience : technology risk governance, incident management, resilience testing, third-party provider risk, and cyber threat information sharing. The regulation states what must be put in place. It does not state what failing to do so costs. Nor does Solvency II, the prudential framework that sets an insurer's capital : its operational risk charge is a percentage of premiums, identical for an exemplary insurer and for a failing one. An executive weighing a compliance budget therefore has no figure to work with.

The difficulty is not the obvious one. The five areas are not independent boxes to tick. Weak governance delays incident detection ; an unmanaged provider opens a door that testing never explored. Failure propagates, and it propagates in a *direction* : one area drags others down, and fixing a cause is worth more than fixing a symptom. Standard statistical tools can represent the fact that several areas fail together, but not which one dragged the others. Yet it is precisely that direction which should dictate the order of remediation work.

What was built. The work represents propagation as a *directed cascade* : an incident starts in one area, then transmits to others through an asymmetric influence matrix calibrated on a corpus of official post-incident reports. The matrix is normalised so that the cascade always dies out, a property guaranteed by construction rather than checked afterwards. The firm's compliance state, area by area, then drives four parameters of the loss distribution : how many incidents occur per year, what share escapes detection, how strongly they propagate, and how far a shared provider makes them converge. Capital is recomputed from that distribution, with no penalty added on top.

The headline result. Between a fully compliant state and a fully failing one, the capital requirement is multiplied by 3,3. More importantly, the four channels are not additive : taken separately they account for two thirds of the gap, and the remaining third, about 35 %, comes from their interactions. One direct consequence for a remediation plan : fixing one area is worth more to a firm that fails everywhere than to a firm otherwise sound, because the fix also closes the interactions that area carried. The figure to quote in an action plan is therefore not the area's standalone effect but its closure effect, which is 1,5 to 3 times larger.

The methodological contribution, which matters more than the figure. The available data does not allow the *direction* of propagation to be observed. This is not a matter of sample size : the observable quantity is mathematically insensitive to direction, so that a matrix and its symmetric counterpart are indistinguishable to the data even though they lead to different decisions. An industry-standard incident schema carries the two required fields and populates both in only one incident out of 10591. Faced with this, the work does not posit an arbitrary value. It computes the *set* of matrices consistent with the data and reports capital as a range over that set. Ignorance thus has a cost known in advance and capped, and most of the additional capital comes from the co-occurrence of failures, which is observable, not from the direction of propagation, which is not. The missing direction shifts the remediation *priority* more than the amount, which is the reason for publishing a ranking of areas rather than a single number.

Limitations, published alongside the result. The absolute capital level is illustrative : it varies widely with the loss database used, and what is defended is the ratio between the two compliance states. An out-of-sample backtest validates the incident count distribution and the shape of the loss tail, but shows that the level of extreme losses drifts faster than the model assumes, so that capital is understated. The same backtest finally quantifies its own power : detecting an anomaly at the regulatory quantile would require more than one thousand eight hundred years of observations, so no existing history can validate that level.